

1 Highlights

2 **SHIELD-AI: A Multi-Layer Governance Framework for Safe and** 3 **Auditable Generative AI Integration in Security Operations Cen-** 4 **ters**

5 Author 1, Author 2, Author 3, Author 4, Author 5, Author 6

- 6 • SHIELD-AI: a **six-layer** governance framework for safe and auditable
7 generative AI in SOCs.
- 8 • GraphRAG Correlation Engine (Layer 3) enabling multi-hop threat
9 reasoning over ATT&CK/IOC graphs.
- 10 • UCO-based Knowledge Layer (Layer 2) with MITRE ATT&CK Graph,
11 IOC Graph, and Asset Graph.
- 12 • Dual-use taxonomy of offensive and defensive GenAI cybersecurity ca-
13 pabilities.
- 14 • Cross-standard control mapping: MITRE ATT&CK/ATLAS, NIST,
15 OWASP, ISO 27001/42001, LGPD.
- 16 • Decision-theoretic human-in-the-loop routing with formally derived
17 thresholds.
- 18 • Scenario evaluation in healthcare and critical-infrastructure contexts.
- 19 • Open-source reference implementation plus reproducible experiment on
20 a synthetic CICIDS-2017-like benchmark.

21 SHIELD-AI: A Multi-Layer Governance Framework for
22 Safe and Auditable Generative AI Integration in
23 Security Operations Centers

24 Author 1^a, Author 2^b, Author 3^c, Author 4^d, Author 5^e, Author 6^f

^aAnonymous University 1, Anonymous Laboratory 1 Anonymous Country 1

^bAnonymous University 2, Anonymous Laboratory 2 Anonymous Country 2

^cAnonymous University 3, Anonymous Laboratory 3 Anonymous Country 3

^dAnonymous University 4, Anonymous Laboratory 4 Anonymous Country 4

^eAnonymous University 5, Anonymous Laboratory 5 Anonymous Country 5

^fAnonymous University 6, Anonymous Laboratory 6 Anonymous Country 6

25 **Abstract**

Security Operations Centers (SOCs) face an unprecedented governance challenge as generative artificial intelligence (GenAI) and large language models (LLMs) are simultaneously weaponised by adversaries—enabling automated phishing, deepfake fraud, AI-assisted malware generation, and adversarial reconnaissance at scale—and adopted defensively as threat-hunting assistants, alert triage engines, and incident-response advisors. This dual-use reality exposes four critical governance gaps that existing standards fail to close in integration: (G1) operational SOC architecture is absent from AI-lifecycle frameworks such as ENISA Multilayer; (G2) agent-governance proposals (LGA, LanG) do not address regulatory compliance; (G3) corporate governance standards (NIST AI RMF, ISO 42001) omit SOC-operational architectural detail; and (G4) no existing framework incorporates Brazil’s Lei Geral de Proteção de Dados (LGPD) explicitly. These gaps leave practitioners without a single, validated artifact that combines SOC-operational architecture, LLM-specific risk controls, human-in-the-loop design, and multi-standard compliance. To close them, we propose **SHIELD-AI**, a six-layer governance framework for safe and auditable generative AI integration in security operations. Grounded in Design Science Research methodology and a systematic literature mapping of 63 verified references, SHIELD-AI encompasses: (i) a dual-use taxonomy of GenAI capabilities in cybersecurity; (ii) a probabilistic risk stratification model for six LLM-specific operational risks;

Email addresses:
Preprint submitted to Computers & Security
author1@anonymous-institution.example (Author 1),
author2@anonymous-institution.example (Author 2),
author3@anonymous-institution.example (Author 3),
author4@anonymous-institution.example (Author 4),
author5@anonymous-institution.example (Author 5),
author6@anonymous-institution.example (Author 6)

July 17, 2026

(iii) a six-layer reference architecture—Data Fabric, UCO-based Knowledge Layer, GraphRAG Correlation Engine, LLM Governance Layer, Human-in-the-Loop, and Compliance & Audit—integrating LLM/GraphRAG pipelines, SIEM data ingestion, human-in-the-loop oversight, and a governance/audit engine; and (iv) a cross-standard control mapping aligning framework controls to MITRE ATT&CK, MITRE ATLAS, NIST CSF 2.0, OWASP LLM Top 10 (2025), ISO/IEC 27001:2022, ISO/IEC 42001:2023, and LGPD. We evaluate SHIELD-AI through scenario-based analysis in healthcare and government critical-infrastructure contexts and through a reproducible reference experiment on a synthetic CICIDS-2017-like benchmark, both released as open-source artefacts. We formalise the framework as a 6-tuple, derive a decision-theoretic threshold for human-in-the-loop escalation, and prove three properties: audit completeness, compliance preservation under control composition, and policy-derivable routing. Results indicate that principled governance integration—rather than unconstrained AI automation—is a necessary condition for safe, explainable, and audit-ready security operations.

Keywords: generative AI, large language model, cybersecurity, security operations center, governance framework, MITRE ATT&CK, OWASP LLM Top 10, human-in-the-loop, hallucination, LGPD, reproducible reference implementation

1. Introduction

The cybersecurity threat landscape is intensifying in both volume and sophistication. The 2025 Verizon Data Breach Investigations Report documented 22,052 incidents and 12,195 breaches in a single observation cycle (Verizon, 2025), while the ENISA Threat Landscape 2025 analysed 4,875 incidents over the period July 2024–June 2025 (ENISA, 2025). Generative artificial intelligence (GenAI) and large language models (LLMs) are reshaping this landscape on both sides simultaneously: by enabling offensive capabilities at scale and by promising transformative gains in defensive operations. Three recent systematic surveys document the acceleration of LLM-related publications in cybersecurity since the 2022 GPT inflection point (Anonymous, 2024c,b, 2025b).

The dual-use reality is documented.. Peer-reviewed evidence of offensive LLM applications now includes spear-phishing campaigns generated against 600+

44 UK Members of Parliament (Hazell, 2023) and comparative evaluations of
45 phishing characterization across Gemini, DeepSeek, and ChatGPT (Anonymous, 2024a). Industry telemetry corroborates a measurable acceleration in
46 AI-enabled adversary behaviour: CrowdStrike reported a 442% increase in
47 voice-phishing (vishing) operations between the first and second halves of
48 2024 (CrowdStrike, 2025); IBM X-Force observed an 84% year-over-year in-
49 crease in infostealer-delivery emails (IBM Security, 2025); Microsoft reported
50 a 32% surge in identity-based attacks in the first half of 2025 (Microsoft,
51 2025). Defensive applications are also accelerating: empirical studies of LLM-
52 analyst collaboration in SOC settings (Singh et al., 2025), multi-agent triage
53 architectures (Anonymous, 2025a), retrieval-augmented threat intelligence
54 (Lekssays et al., 2025; Fayyazi et al., 2024), and CyberSecEval benchmarks
55 measuring LLM cybersecurity knowledge and risk (Bhatt et al., 2023, 2024;
56 Wan et al., 2024).

58 *The compound risk..* Organisations integrating LLMs into SOC pipelines face
59 a new class of operational risks: hallucination in decision-critical pipelines (Ji
60 et al., 2023; Manakul et al., 2023); prompt injection (Greshake et al., 2023;
61 Liu et al., 2024); universal adversarial attacks against alignment safeguards
62 (Zou et al., 2023); tool poisoning and agentic-AI failure modes (OWASP
63 Foundation, 2025b,a); and data leakage through prompts. The IBM 2025
64 Cost of a Data Breach report quantifies the governance gap directly: 97%
65 of organisations breached after an AI-related incident lacked appropriate AI
66 access controls, and 63% had no AI governance policy in place (IBM Security
67 and Ponemon Institute, 2025). The 2025 Microsoft Digital Defense Report
68 corroborates this with measured identity-attack growth and an 87% increase
69 in destructive cloud campaigns (Microsoft, 2025).

70 *The standards gap..* Existing standards address fragments of the problem.
71 The OWASP Top 10 for LLM Applications (2025 edition) catalogues generic
72 LLM risks (OWASP Foundation, 2024); the OWASP Top 10 for Agentic Ap-
73 plications, released in December 2025, addresses agent-specific failure modes
74 (OWASP Foundation, 2025b,a). MITRE ATLAS (The MITRE Corporation,
75 2025) provides a tactics-and-techniques taxonomy for AI as the target of
76 attacks. The NIST AI Risk Management Framework (NIST, 2023) and
77 its Generative AI Profile (NIST, 2024a) define cross-sectoral risk manage-
78 ment functions. ISO/IEC 42001:2023 defines an AI management system
79 standard (ISO/IEC, 2023). International joint guidance from CISA and

80 partner agencies (NCSC et al., 2023; NSA AISC et al., 2024; CISA, 2023)
 81 provides secure-by-design and deployment guidance. ENISA’s Multilayer
 82 Framework for Good Cybersecurity Practices for AI (ENISA, 2023) proposes
 83 three lifecycle-oriented layers. Recent peer-reviewed work has begun to con-
 84 verge on layered-governance architectures for autonomous agents (Ge, 2026;
 85 Anonymous, 2026; Abuadbbba et al., 2026) and on the under-recognised prob-
 86 lem of machine-identity governance (Kurtz and Krawiecka, 2026), but each
 87 addresses a sub-problem rather than a SOC-integrated, multi-standard syn-
 88 thesis. None of these, in particular, combines a SOC-operational architecture
 89 with depth on LLM-as-tool risks, regulatory compatibility with regimes such
 90 as Brazil’s LGPD (Brasil, 2018), and cross-standard control mapping in a
 91 single, validated artifact.

92 *Four governance gaps that remain open..* A systematic comparison of exist-
 93 ing artifacts (Table 2) reveals four gaps that none of them closes individually
 94 or in combination:

95 **G1 – SOC operational architecture.** ENISA’s Multilayer Framework
 96 (ENISA, 2023) addresses AI system lifecycle security but does not
 97 specify an operational SOC architecture. No existing standard defines
 98 how LLM pipelines integrate with SIEM, SOAR, EDR, and Threat
 99 Intelligence feeds inside a SOC.

100 **G2 – Agent governance without regulatory compliance.** The Lay-
 101 ered Governance Architecture (LGA) (Ge, 2026) and LanG (Anony-
 102 mous, 2026) govern autonomous agents and achieve strong empirical
 103 results (93–98.5% interception), but neither incorporates compliance
 104 with data-protection regimes such as LGPD, GDPR, or sector-specific
 105 obligations.

106 **G3 – Operational architecture absent from compliance standards.**
 107 NIST AI RMF (NIST, 2023) and ISO/IEC 42001:2023 (ISO/IEC,
 108 2023) define management-system requirements for AI governance but
 109 provide no SOC-level architectural primitives, leaving practitioners
 110 with a significant implementation gap.

111 **G4 – Brazilian regulatory context unaddressed.** No existing
 112 framework—international or academic—explicitly integrates Brazil’s
 113 LGPD (Brasil, 2018) or accounts for ANPD resolutions on inci-
 114 dent notification (ANPD, 2024c) and the proposed Marco Legal

115 da IA (PL 2338/2023) (Brasil, 2023). Brazil operates one of the
116 world’s largest critical-infrastructure SOC ecosystems, yet regulatory
117 alignment for this context remains absent from the literature.

118 These four gaps compound each other: a practitioner who wishes to deploy
119 GenAI safely in a Brazilian government SOC simultaneously needs (G1) an
120 architecture that integrates SIEM and LLM pipelines, (G2) agent-governance
121 guardrails, (G3) compliance mapping, and (G4) LGPD alignment—no exist-
122 ing single artifact provides all four. SHIELD-AI is proposed as a direct
123 consequence of this demonstrated gap landscape.

124 *Research questions..* We pose:

- 125 • **RQ0 (Primary).** How can organisations design, deploy, and govern
126 GenAI within security operations while mitigating LLM-specific opera-
127 tional risks; hallucination, prompt injection, tool poisoning, shadow AI,
128 accountability gaps; without sacrificing threat detection effectiveness or
129 regulatory compliance?
- 130 • **RQ1.** What offensive capabilities does GenAI provide to adversaries
131 and how should these be taxonomised for defensive threat modelling?
- 132 • **RQ2.** What technical and governance controls are necessary and suf-
133 ficient to mitigate LLM-specific risks in SOC contexts?
- 134 • **RQ3.** How can human-in-the-loop oversight, explainability, and audit
135 logging be architecturally integrated without unacceptable throughput
136 loss?
- 137 • **RQ4.** How does a principled framework align with and extend MITRE
138 ATT&CK, MITRE ATLAS, NIST CSF 2.0, OWASP LLM Top 10, ISO
139 27001, ISO 42001, and LGPD?
- 140 • **RQ5.** What adaptations are required for regulated environments;
141 healthcare, government, critical infrastructure?

142 *Contributions..* This paper makes nine contributions: (C1) a dual-use
143 taxonomy of GenAI in cybersecurity (Table 3); (C2) the SHIELD-AI
144 framework as a **six-layer** reference architecture (Section 6, Figure 4),
145 extending the V3 four-layer design with a UCO-based Knowledge Layer
146 and a GraphRAG Correlation Engine to address relational threat analysis

in SOC environments; (C3) a cross-standard control mapping (Table 7, Figure 7); (C4) an LLM-specific risk model with tiered controls (Section 5, Table 5); (C5) a governance metric set with a composite governance score (Section 7, Table 8); (C6) critical-sector application scenarios for healthcare and government (Section 8); (C7) an open-source reference implementation and a reproducible empirical evaluation on a synthetic CICIDS-2017-like benchmark (Section 9.3)¹; (C8) a research agenda (Section 10); and (C9) a GraphRAG threat-correlation architecture grounded in the Unified Cyber Ontology (UCO), providing multi-hop reasoning over ATT&CK, IOC, and asset graphs to reduce hallucination and produce auditable inference chains (Section 6.4). We formalise SHIELD-AI as a 6-tuple, derive the human-in-the-loop escalation threshold from decision-theoretic principles, and prove three governance properties (audit completeness, compliance preservation under composition, policy-derivable routing). Section 3 describes the Design Science Research methodology that grounds the artifact.

2. Background and Related Work

2.1. Generative AI and LLMs in cybersecurity: overview

Transformer-based language models trained on massive corpora, often followed by reinforcement learning from human feedback (RLHF), have produced systems with strong general-purpose generation and reasoning capabilities. Retrieval-augmented generation (RAG) couples these systems to authoritative corpora at inference time, mitigating but not eliminating hallucination. Agentic patterns extend LLMs with tool-using capabilities, enabling autonomous workflows; but introducing new failure modes (OWASP Foundation, 2025b). Anderson’s foundational treatment of security engineering principles (Anderson, 2020), while pre-LLM, establishes the security-by-design lineage SHIELD-AI inherits.

2.2. Offensive AI: evidence from the literature and threat intelligence

Peer-reviewed evidence demonstrates that GenAI lowers the cost of high-quality phishing message generation (Hazell, 2023), including in Brazilian

¹Reference implementation and experimental harness: <https://github.com/ufxa/SHIELD-AI-A-Multi-Layer-Governance-Framework>. The benchmark is synthetic, mirroring the CICIDS-2017 schema; results are not transferable to real CICIDS-2017 traffic without re-running the harness against the published CSVs.

177 Portuguese contexts (Anonymous, 2024a). Industry telemetry shows conver-
 178 gent patterns across multiple vendors: stolen credentials dominate as ini-
 179 tial access vector, with 22% of breaches in DBIR 2025 (Verizon, 2025) and
 180 infostealer-email volumes up 84% year over year (IBM Security, 2025). Voice
 181 phishing surged 442% within 2024 (CrowdStrike, 2025), indicating measur-
 182 able AI-enabled scale-up of social-engineering attacks. Cross-vendor conver-
 183 gence on these trends provides triangulated evidence: when only one source
 184 reports a trend, it may reflect sampling bias, but when DBIR (Verizon, 2024,
 185 2025), Microsoft (Microsoft, 2024, 2025), IBM (IBM Security, 2024, 2025),
 186 Mandiant (Mandiant and Google Cloud, 2024, 2025), CrowdStrike (Crowd-
 187 Strike, 2024, 2025), and ENISA (ENISA, 2024, 2025) agree, the signal is
 188 high-confidence.

189 *2.3. Defensive AI in security operations*

190 Empirical work establishes that LLMs can augment SOC analyst work-
 191 flows (Singh et al., 2025) and that multi-agent decompositions of triage tasks
 192 are feasible (Anonymous, 2025a). Recent advances in RAG over MITRE
 193 ATT&CK enable hypothesis generation with explicit retrieval grounding
 194 (Lekssays et al., 2025; Fayyazi et al., 2024; Blefari et al., 2025), addressing
 195 the central reliability challenge of LLM-augmented threat hunting. Cyber-
 196 RAG (Blefari et al., 2025) demonstrates iterative retrieval-and-reason loops
 197 with fine-tuned classifier ensembles for real-time attack classification. The
 198 LanG platform (Anonymous, 2026) couples an agentic orchestrator with
 199 Model-Context-Protocol-mediated tool governance, reporting a two-layer
 200 guardrail pipeline at 98.1% F1 score and providing the closest published
 201 artifact to SHIELD-AI on the dimension of governance-by-design SOC
 202 operations. The Layered Governance Architecture (LGA) of Ge (2026)
 203 proposes a four-layer agent governance design (execution sandboxing, intent
 204 verification, zero-trust authorization, immutable audit) evaluated on a
 205 1,081-sample bilingual tool-call benchmark, intercepting 93.0–98.5% of
 206 malicious tool calls in intent-verification trials. Benchmark suites such as
 207 CyberSecEval 1–3 quantify model behaviour on secure-code generation,
 208 cyberattack assistance, and broader cybersecurity capabilities (Bhatt et al.,
 209 2023, 2024; Wan et al., 2024). Three contemporaneous surveys provide
 210 complementary positioning (Yao et al., 2024; Anonymous, 2024c,b).

211 2.4. LLM-specific risks

212 The hallucination phenomenon was systematised by Ji et al. (2023); zero-
213 resource detection via self-consistency was demonstrated by Manakul et al.
214 (2023). Direct prompt injection (Liu et al., 2024) and indirect prompt in-
215 jection (Greshake et al., 2023) are now formalised and benchmarked. Zou
216 et al. (2023) showed that aligned models can be defeated by adversarial suf-
217 fixes that transfer across model families. The OWASP Top 10 for LLM
218 Applications 2025 (OWASP Foundation, 2024) catalogues these risks with
219 a practitioner orientation, while the OWASP Top 10 for Agentic Applica-
220 tions (OWASP Foundation, 2025b) addresses the cascading failure modes of
221 agent-using systems.

222 2.5. Adjacent industrial guardrail systems

223 SHIELD-AI’s Layer 2 prompt-injection defences and Layer 4 audit invari-
224 ant relate to industry-grade guardrail systems whose source code or spec-
225 ifications are publicly available. NVIDIA NeMo Guardrails offers a pro-
226 grammable runtime for dialog-level and tool-call rails configurable in Colang,
227 with empirical reports on latency overhead and topical/jailbreak rail cov-
228 erage. Microsoft Azure AI Content Safety and prompt-shield services pro-
229 vide policy-anchored content-classification and prompt-injection detection.
230 LangChain and the broader Model-Context-Protocol (MCP) ecosystem ex-
231 pose patterns for tool-allowlisting, structured prompt templates, and per-tool
232 authorization, with recent work formalising kernel-level tool governance via
233 logit-based safety primitives. Adjacent research strands include safety-kernel
234 designs that isolate trusted decision logic from untrusted LLM outputs, and
235 policy-as-code compilers that translate written governance text into runtime-
236 enforceable rule sets. These artefacts are complementary rather than com-
237 peting: SHIELD-AI Layer 2 can adopt NeMo-style rails or Azure-style clas-
238 sifiers as sub-components, the policy-as-code compiler pattern fits naturally
239 into Layer 4’s compliance gate, and the cross-standard mapping in Table 7
240 explicitly identifies the standards under which each rail/classifier counts as
241 a satisfied control.

242 *Head-to-head positioning vs. closest peers..* Table 1 consolidates a head-to-
243 head positioning of SHIELD-AI against the closest contemporary peers (LGA,
244 LanG, 4C, AIRT/MIGT, ENISA Multilayer). Cells use “P” (primary contri-
245 bution of the peer), “I” (integrated as a sub-component or covered by another
246 mechanism), and “–” (out of scope). The intent is not to claim SHIELD-AI

subsumes these works; rather to make the complementary scope explicit so that practitioners can adopt the right tool for the right concern.

Table 1: Head-to-head positioning of SHIELD-AI vs. closest peers.

Concern	ENISA	LGA	LanG	4C	AIRT/MIGT	SHIELD-AI
Layered governance architecture	P (lifecycle)	P (agent)	P (SOC)	–	–	P (SOC)
Tool-call governance (MCP-style)	–	I	P	–	–	I
Reliability triple (θ, σ, γ)	–	I	I	–	–	P
Decision-theoretic HITL threshold	–	–	–	–	–	P
Machine-identity governance	–	I	I	I	P	I (Table 6)
Cross-standard control mapping (7 std.)	–	–	–	–	I	P
LGPD integration	–	–	–	–	–	P
Adversary model for governance layer	–	I	I	I	–	P (§6.8)
Quantitative guardrail benchmark	–	P	P	–	–	planned (OP9, OP11)
Engineering invariants (E1–E3)	–	–	–	–	–	P (Lemma 1)
Cryptographic audit immutability	–	I	–	–	I	P (Merkle + transparency log)
Sustainability and supply-chain SBOMs	–	–	–	–	–	P (OP10)

2.6. Standards and frameworks

Three standards bodies converge on AI security and governance. NIST publications include the AI RMF 1.0 (NIST, 2023), the GenAI Profile (NIST, 2024a), the CSF 2.0 (NIST, 2024b), and SP 800-207 on Zero Trust Architecture (Rose et al., 2020). MITRE provides ATT&CK (The MITRE Corporation, 2024) for adversary tactics and ATLAS (The MITRE Corporation, 2025) for AI-system threats. The OWASP GenAI Security Project produces the LLM Top 10 (OWASP Foundation, 2024), the Agentic Top 10 (OWASP Foundation, 2025b), and the Agentic Threats & Mitigations series (OWASP Foundation, 2025a). ISO/IEC 27001:2022 (ISO/IEC, 2022) and ISO/IEC 42001:2023 (ISO/IEC, 2023) provide ISMS and AI-MS requirements respectively. Joint international guidance includes CISA + NCSC + 21 partner agencies (NCSC et al., 2023) and the seven-nation guidance for deploying AI systems securely (NSA AISC et al., 2024), complemented by CISA’s Roadmap for AI (CISA, 2023). Recent peer-reviewed governance frameworks complement these standards: the 4C Framework of Abuadbbba et al. (2026) organises agentic-AI risks across Core, Connection, Cognition, and Compliance dimensions, drawing on human-society governance metaphors; the AIRT/MIGT taxonomy of Kurtz and Krawiecka (2026) addresses the

under-recognised machine-identity governance problem with 37 risk subcategories across eight domains, observing that agent-to-human identity ratios exceed 80:1 in modern enterprises and that ungoverned machine credentials have been operationalised by nation-state actors.

2.7. The Brazilian regulatory context

Brazil’s Lei Geral de Proteção de Dados (LGPD, Lei 13.709/2018) (Brasil, 2018) establishes a GDPR-like personal data protection regime; Articles 46–48 govern security measures, breach notification, and data-protection officer obligations. ANPD has issued binding resolutions on incident communication (Resolução 15/2024) (ANPD, 2024c), on the data-protection officer (Resolução 18/2024) (ANPD, 2024d), and on the authority’s own internal policy (Resolução 20/2024) (ANPD, 2024e); orientation guides include security guidance for small data-handling agents (ANPD, 2024a,b). The Marco Legal da Inteligência Artificial (PL 2338/2023) (Brasil, 2023) introduces a risk-based AI regulation modelled on the EU AI Act, approved in the Federal Senate on December 10, 2024, and under review in the Chamber of Deputies in 2026.

Transferability to peer regimes. While the running examples in this paper use LGPD, the framework’s regulatory column in Table 7 is intentionally jurisdiction-portable. LGPD Articles 46–48 correspond closely to GDPR Articles 32 (security of processing), 33 (notification of breaches), 35 (data protection impact assessment) and 37 (data-protection officer); to security duties under CCPA / CPRA in California; and to comparable obligations in India’s Digital Personal Data Protection Act 2023. Layer 4 of SHIELD-AI implements these duties as compliance gates that can be re-instantiated per jurisdiction by substituting the controlling text without altering the architectural primitives.

2.8. Research gap analysis

The closest pre-art is the ENISA Multilayer Framework for Good Cybersecurity Practices for AI (ENISA, 2023). SHIELD-AI differs along four explicit dimensions: (i) operational scope; SOC-operational vs. AI-system-lifecycle; (ii) LLM-as-tool risk depth; hallucination, prompt injection, and tool poisoning treated as architectural concerns rather than as practice notes; (iii) cross-standard mapping; SHIELD-AI integrates seven standards (MITRE ATT&CK + ATLAS + NIST CSF + OWASP LLM Top 10 + ISO 27001 + ISO 42001 + LGPD), while ENISA does not include LGPD or perform

integrated mapping; (iv) human-in-the-loop; SHIELD-AI treats HITL as a first-class architectural layer, not as a practice within layers. To make the gap concrete we summarise the coverage of the eight relevant gap dimensions across the closest pre-art in Table 2: existing artifacts cover individual pieces while no single source closes all eight. We honestly note that this is a synthesis gap rather than an absence-of-work gap: the contribution lies in the integration, not in claiming each dimension is unaddressed elsewhere.

Table 2: Research gap matrix (extended). Cells: ✓ = primary coverage, ~ = partial,; = not covered. SHIELD-AI is the only single source closing all eight dimensions. Recent governance-oriented works (LGA, LanG, 4C, AIRT/MIGT) cover important sub-problems; SHIELD-AI complements them with cross-standard mapping including LGPD and SOC-operational integration.

Gap dimension	ENISA	OWASP LLM	OWASP A.	NIST AI RMF	NIST CSF	ATLAS	LGA	LanG	4C	AIRT/MIGT	SHIELD-AI
Dual-use taxonomy (post-2022)	~	n/a	n/a	n/a	n/a	~	n/a	n/a	~	n/a	✓
SOC-op LLM risk model	n/a	~	~	n/a	n/a	n/a	~	✓	~	n/a	✓
Integrated architecture w/ HITL	n/a	n/a	n/a	n/a	n/a	n/a	✓	✓	n/a	n/a	✓
Cross-standard mapping (≥ 7 std.)	n/a	n/a	n/a	n/a	n/a	n/a	n/a	n/a	n/a	~	✓
LGPD integration	n/a	n/a	n/a	n/a	n/a	n/a	n/a	n/a	n/a	~	✓
Validated critical-sector application	~	n/a	n/a	~	~	n/a	~	~	n/a	~	✓
HITL as architectural layer	n/a	n/a	n/a	n/a	n/a	n/a	✓	✓	n/a	n/a	✓
Machine-identity governance integration	n/a	n/a	~	n/a	n/a	n/a	~	~	n/a	✓	✓
Research agenda for AI governance in cybersec	n/a	n/a	n/a	~	n/a	n/a	n/a	n/a	~	~	✓

2.8.1. Concrete contrast: ENISA practice vs. SHIELD-AI primitive

A side-by-side example clarifies the operational difference. ENISA’s Multilayer Framework (ENISA, 2023) prescribes *model security testing* as a practice within its AI-specific cybersecurity layer. The practice is described as a recurring activity in which AI systems are tested for robustness, evasion, and poisoning. SHIELD-AI translates the same intent into the architectural primitive of the reliability triple (θ, σ, γ) computed at Layer 2 for every output, with σ realising the spirit of robustness testing through self-consistency (Manakul et al., 2023) and γ realising the spirit of poisoning detection through grounding against MITRE ATT&CK (The MITRE Corporation, 2024). The two artifacts are complementary: ENISA describes *when* and *whether* testing should occur as part of an AI lifecycle; SHIELD-AI specifies *how* reliability signals are computed and *how* they route decisions at Layer 3. A SOC adopting SHIELD-AI satisfies the ENISA practice by construction; a SOC adopting only ENISA still requires a layer-architectural translation, which SHIELD-AI provides.

326 **3. Research Method**

327 *3.1. Design Science Research*

328 SHIELD-AI is a design artifact and we adopt Design Science Research
329 (DSR) following Hevner et al. (Hevner et al., 2004) for the relevance–rigor–
330 design framing and Peffers et al. (Peffers et al., 2007) for the six-step process:
331 problem identification, objectives, design and development, demonstration,
332 evaluation, communication. DSR is the appropriate methodology because
333 the contribution is a design (a framework with controls, architecture, and
334 mapping) rather than a theory or an empirical study.

335 *3.2. Systematic literature mapping*

336 We executed a focused systematic literature mapping (SLM) restricted
337 to open-access sources to enable transparent replication. Search strings com-
338 bined GenAI vocabulary (“generative AI”, “large language model”, “LLM”)
339 with cybersecurity vocabulary (“cybersecurity”, “security operations”,
340 “SOC”, “threat hunting”) and governance vocabulary (“risk”, “governance”,
341 “framework”, “hallucination”, “prompt injection”). The temporal window
342 was 2023–2026 plus foundational classics. Sources included arXiv (cs.CR),
343 USENIX, ACM Open, IEEE Open, NIST, ENISA, CISA, MITRE, OWASP,
344 SBC OpenLib, JBCS, JHI, and authoritative gray literature (Verizon DBIR,
345 Microsoft DDR, IBM X-Force, Mandiant M-Trends, CrowdStrike GTR).
346 The mapping produced 63 verified references; verification was by direct
347 URL fetch with metadata confirmation. The full inclusion/exclusion criteria
348 appear in Appendix A.

349 *3.3. Threat modelling*

350 Risks were elicited using STRIDE-based threat modelling against the
351 SHIELD-AI reference architecture, grounded in ATT&CK (The MITRE Cor-
352 poration, 2024) for cyber tactics and ATLAS (The MITRE Corporation,
353 2025) for AI-targeted tactics. Each identified risk was characterised by base
354 probability, normalised impact, and candidate controls (Section 5).

355 *3.4. Framework evaluation strategy*

356 We evaluate SHIELD-AI through (i) scenario-based analysis applied to
357 two structured scenarios (healthcare under LGPD; government / critical in-
358 frastructure under PNSI), (ii) comparative analysis against the ENISA Multi-
359 layer Framework (ENISA, 2023), and (iii) framework-quality scoring (utility,

completeness, novelty, usability). In DSR terminology (Peffers et al., 2007), the scenario-based analysis corresponds to Demonstration (Step 4) of the artifact applied to two structured contexts; empirical Evaluation (Step 5) against operational SOC environments is identified in §10.5 as Open Problem OP1 and is the subject of a planned follow-up study. The full methodology flow appears in Figure 1.

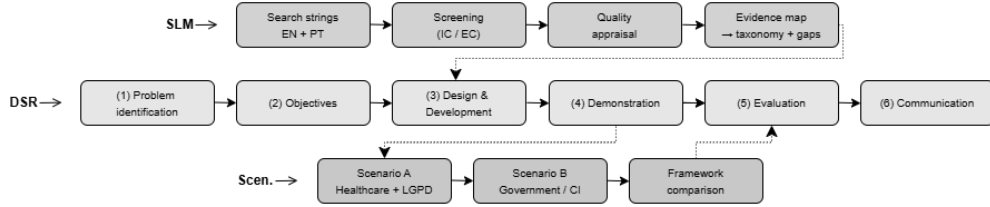


Figure 1: Research method flow combining Design Science Research (top), Systematic Literature Mapping (middle), and scenario-based evaluation (bottom).

4. Dual-Use AI Taxonomy in Cybersecurity

The offensive–defensive duality of GenAI in cybersecurity is illustrated in Figure 2. Adversaries use LLMs to accelerate reconnaissance, generation of social-engineering or malicious content, delivery, and exploitation; defenders use LLMs to accelerate detection, hunting, response, and governance. The two cycles share a co-evolution surface: prompt injection (Greshake et al., 2023; Liu et al., 2024; Zou et al., 2023) and tool poisoning (OWASP Foundation, 2025b) attack the defensive AI itself.

Table 3 consolidates the verified evidence into a dual-use taxonomy. Offensive categories are documented in peer-reviewed work (Hazell, 2023; Anonymous, 2024a; Bhatt et al., 2023) and authoritative threat intelligence (Verizon, 2025; Microsoft, 2025; CrowdStrike, 2025; IBM Security, 2025); defensive categories are documented in recent experimental work (Singh et al., 2025; Anonymous, 2025a; Lekssays et al., 2025; Fayyazi et al., 2024).

Approach comparison.. Defensive deployments must choose among rule-based, classical ML, and LLM/RAG approaches. Each occupies a distinct point in the cost–reliability–explainability space (Table 4). Rule-based approaches have high precision at low false-positive rates but plateau at modest true-positive rates; classical ML offers balanced area-under-the-curve

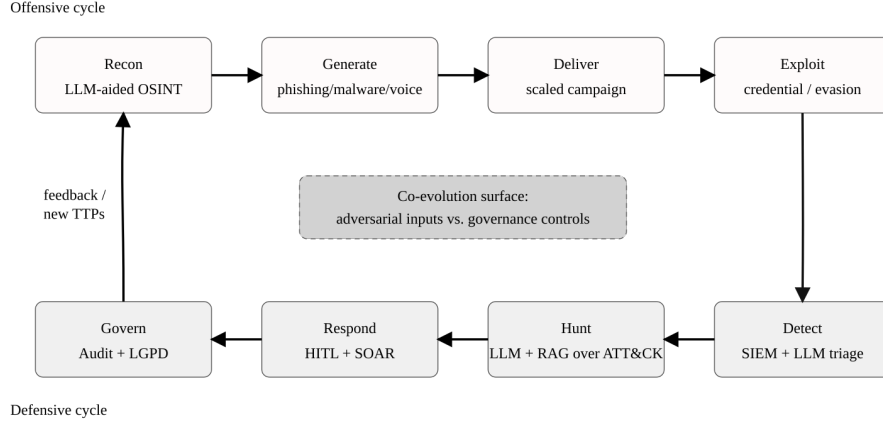


Figure 2: Offensive-defensive AI co-evolution cycle in cybersecurity.

Table 3: Dual-use AI taxonomy in cybersecurity. Direction: O = offensive; D = defensive.

Category	Subcategory	Mechanism	Dir.	Anchors
Social engineering	Spear phishing	LLM + OSINT context	O	(Hazell, 2023; Anonymous, 2024a)
Social engineering	Vishing / voice clone	TTS + LLM script	O	(CrowdStrike, 2025)
Malware	Insecure code	LLM coding assistance	O	(Bhatt et al., 2023, 2024)
Malware	Evasion assistance	Polymorphism / rewrite	O	(Wan et al., 2024)
Reconnaissance	OSINT enrichment	LLM + public data	O	(Hazell, 2023)
SOC defence	Alert triage	LLM agent + SIEM	D	(Singh et al., 2025; Anonymous, 2025a)
SOC defence	Threat hunting	LLM + RAG over ATT&CK	D	(Lekssays et al., 2025; Fayyazi et al., 2024)
SOC defence	Incident response	LLM agent + SOAR	D	(Singh et al., 2025)
SOC defence	Report writing	LLM + audit log	D	(Singh et al., 2025)
Governance	Compliance check	LLM + standards corpus	D	(OWASP Foundation, 2024; ISO/IEC, 2023)

performance with explanation tools (SHAP, LIME); LLM/RAG offers the highest ceiling but is sensitive to prompt design and adversarial input (Liu et al., 2024; Zou et al., 2023). Figure 3 illustrates these qualitative trade-offs.

5. LLM-Specific Risks in Security Operations

We identify six LLM-specific risk classes that emerge when LLMs are deployed in SOC pipelines. Each is grounded in peer-reviewed evidence and / or authoritative standards.

R1. Hallucination in decision-critical pipelines. The systematic survey by Ji et al. (2023) catalogues hallucination types and detection methods. Manakul et al. (2023) demonstrate zero-resource detection via self-consistency. In SOC

Table 4: Comparison of defensive approaches.

Dimension	Rule-based	Classical ML	LLM / RAG
Detection mechanism	Pattern match	Statistical learning	Generative + retrieval
False positives	High (brittle)	Medium (model-dependent)	Variable, prompt-sensitive
Explainability	High (rules)	Medium (SHAP/LIME)	Low (partial reasoning trace)
Maintenance	Manual rules	Periodic retraining	Prompt + corpus + model
Adversarial robustness	Low	Medium	Low without controls
Latency	Low	Low-medium	High
Cost per query	Negligible	Low	Material

395 contexts, hallucination can manifest as fabricated threat-intel claims, invalid
 396 playbook steps, or misattributed indicators of compromise.

397 *R2. Prompt injection..* Direct prompt injection (Liu et al., 2024) and indirect
 398 prompt injection through retrieved or referenced content (Greshake et al.,
 399 2023) can subvert LLM behaviour. Zou et al. (2023) showed that aligned
 400 models can be defeated by adversarial suffixes that transfer across model
 401 families, defeating alignment-only defences.

402 *R3. Tool poisoning and agentic-AI failures..* The OWASP Top 10 for Agentic
 403 Applications (OWASP Foundation, 2025b) enumerates goal hijacking, tool
 404 misuse, identity abuse, supply-chain compromise, and cascading failures. In
 405 SOC contexts these translate to SOAR action misuse, false ticket closure,
 406 and integrity drift across the response chain.

407 *R4. Data leakage through prompts..* The IBM Cost of a Data Breach 2025
 408 report found that 97% of breached organisations with AI-related incidents
 409 lacked appropriate AI access controls, and 63% had no AI governance policy
 410 (IBM Security and Ponemon Institute, 2025). SOC contexts handle PII, CTI
 411 feeds with sensitive attribution, and incident details whose exposure violates
 412 LGPD Articles 46–48 (Brasil, 2018).

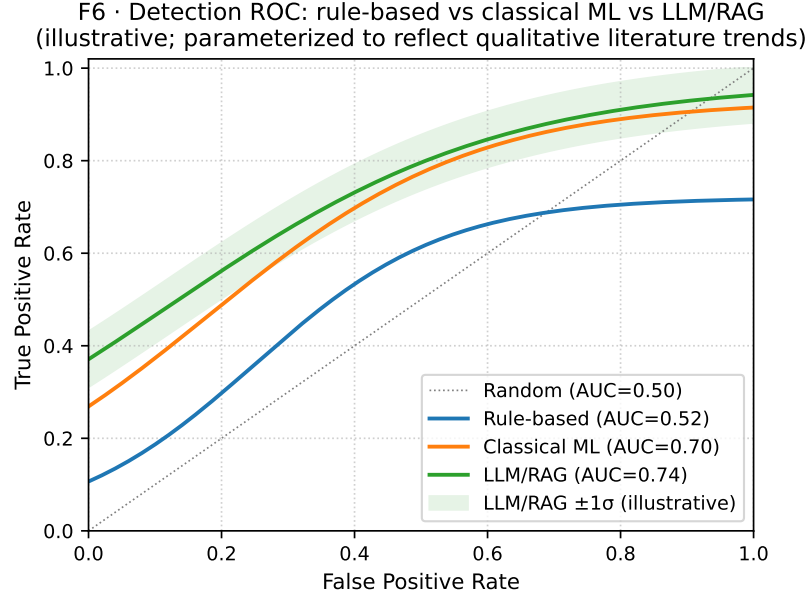


Figure 3: Qualitative comparison of detection regimes (rule-based, classical ML, LLM/RAG) drawn from qualitative literature trends. The curves are parameterised, not experimental; experimental anchoring against published benchmarks (e.g., CyberSecEval (Bhatt et al., 2023), CICIDS-2017) is identified as Open Problem OP1 in §10.5 and is the subject of a companion experimental study.

413 *R5. Over-automation and human displacement..* Empirical evidence on
 414 LLM-analyst collaboration (Singh et al., 2025) indicates that misplaced
 415 trust in LLM outputs can erode analyst skill and obscure accountability
 416 when decisions are auto-executed.

417 *R6. Shadow AI and governance evasion..* Unsanctioned AI tool adoption
 418 proliferates outside governance controls, evidenced by the AI-governance gap
 419 measured by IBM (IBM Security and Ponemon Institute, 2025) and corroborated by Microsoft (Microsoft, 2025).

421 Table 5 consolidates these risks with tiered mitigating controls.

422 6. The SHIELD-AI Framework

423 6.1. Design principles

424 SHIELD-AI is governed by nine design principles. (DP1) *Governance-*
 425 *by-design*: every operational layer has a governance counterpart in Layer 6.

426 (DP2) *Risk stratification*: controls are tiered by NIST CSF Implementation
 427 Tiers (NIST, 2024b) and OWASP risk ranking (OWASP Foundation, 2024).
 428 (DP3) *HITL as architectural primitive*, not as practice. (DP4) *Zero-trust*
 429 *grounding* (Rose et al., 2020): no implicit trust in LLM outputs or tool
 430 actions. (DP5) *Auditability*: every LLM-mediated decision is traceable to
 431 inputs, prompt, model, output, and human review state. (DP6) *Standards-*
 432 *aligned controls*: every control maps to ≥ 1 external standard (Table 7).
 433 (DP7) *Regulatory compatibility*: LGPD (Brasil, 2018) and equivalent regimes
 434 are first-class concerns. (DP8) *Relational knowledge*: threat analysis in SOC
 435 contexts is inherently relational; the knowledge layer must support graph
 436 traversal over entities (hosts, users, IPs, techniques, campaigns), not only
 437 vector similarity over documents. (DP9) *Semantic interoperability*: all threat
 438 entities are typed according to the Unified Cyber Ontology (UCO), enabling
 439 standardised reasoning across heterogeneous SOC data sources.

440 6.2. Formal definition

441 We formalise SHIELD-AI as a 6-tuple.

442 **Definition 1** (SHIELD-AI Framework). *The SHIELD-AI governance frame-*
 443 *work is a tuple $\mathcal{S} = \langle \mathcal{L}, \mathcal{C}, \mathcal{M}, \mathcal{R}, \mathcal{A}, \mathcal{P} \rangle$ where: $\mathcal{L} = \{L_1, L_2, L_3, L_4, L_5, L_6\}$*
 444 *is the ordered set of six architectural layers (Data Fabric, Knowledge,*
 445 *GraphRAG Correlation, LLM Governance, Human-in-the-Loop, Com-*
 446 *pliance & Audit); $\mathcal{C}$ is the set of named controls; $\mathcal{M} : \mathcal{C} \rightarrow 2^{\mathcal{E}}$ maps*
 447 *each control to a non-empty subset of external standards $\mathcal{E}$; $\mathcal{R}$ is*
 448 *the set of identified LLM-specific risks; $\mathcal{A}$ is the audit invariant re-*
 449 *quiring that every decision $d \in \mathcal{D}$ have an audit record containing*
 450 *$\langle \text{input}, \text{prompt}, \text{graph_path}, \text{output}, \langle \theta, \sigma, \gamma, \rho \rangle, \text{route}, \text{analyst}, \text{timestamp} \rangle$,*
 451 *where ρ is the GraphRAG path confidence (Definition 3); and $\mathcal{P}$ is the set of*
 452 *governance properties guaranteed by the construction.*

453 The reliability triple $\langle \theta, \sigma, \gamma \rangle$ comprises model confidence θ , self-
 454 consistency σ across $k \geq 3$ samples (per Manakul et al. (2023)), and
 455 RAG-groundedness γ (per Lekssays et al. (2025); Fayyazi et al. (2024);
 456 Blefari et al. (2025)). The composite reliability is $R = \omega_\theta \theta + \omega_\sigma \sigma + \omega_\gamma \gamma$
 457 with default weights (0.2, 0.3, 0.5). The default weights are organisational
 458 policy choices subject to empirical calibration; we identify their data-driven
 459 derivation as Open Problem OP8 in §10.5.

460 *Operationalising γ ..* Earlier work leaves γ informally defined. We decompose
 461 RAG-groundedness into four measurable sub-signals so that practitioners can
 462 implement Layer 2 with a concrete estimator:

$$\gamma = \omega_{CC} \cdot CC + \omega_{ES} \cdot ES + \omega_{GD} \cdot GD + \omega_{RS} \cdot RS, \quad (1)$$

463 where (i) **CC** (*Citation Coverage*) is the fraction of factual claims in the
 464 LLM output with an explicit citation to a retrieved corpus chunk; (ii) **ES**
 465 (*Entailment Score*) is the natural-language-inference entailment score of the
 466 LLM output against the retrieved chunks (computable via DeBERTa-MNLI
 467 or equivalent); (iii) **GD** (*Grounding Density*) is the ratio of grounded n-gram
 468 tokens to total answer tokens; and (iv) **RS** (*Retrieval Stability*) is the Jaccard
 469 stability of the retrieved chunk set across $k \geq 3$ paraphrased queries. Each
 470 sub-signal is implementable on open models; sub-signal weights are calibrated
 471 per-deployment using the procedure of OP8.

472 *Adversarial-aware γ' for retrieval-poisoning resistance..* Retrieval poisoning
 473 (Greshake et al., 2023; Liu et al., 2024) can craft inputs that make the four
 474 sub-signals of Equation (1) artificially high while the LLM output remains
 475 factually wrong. To resist this attack vector, Layer 2 also computes a trust-
 476 weighted variant

$$\gamma' = \gamma \cdot \tau(\text{corpus}), \quad (2)$$

477 where $\tau(\text{corpus}) \in [0, 1]$ aggregates corpus-provenance signals: signed re-
 478 leases (e.g., MITRE ATT&CK and MITRE ATLAS official releases (The
 479 MITRE Corporation, 2024, 2025)), publisher reputation for MISP/OpenCTI
 480 feeds, and content-hash lineage of every retrieved chunk. PC3 routes on
 481 $\min(\gamma, \gamma')$; the gap $\gamma - \gamma'$ is itself an auditable signal of potential retrieval-
 482 poisoning exposure and is recorded in Layer 4’s audit log per the audit in-
 483 variant $\mathcal{A}$.

484 6.3. Architectural overview

485 SHIELD-AI consists of **six layers** governed top-down by standards-
 486 aligned policy and producing upward flows of events, decisions, and audit
 487 signals (Figure 4). The V4 architecture extends the original four-layer
 488 design by adding a UCO-based *Knowledge Layer* (L2) and a *GraphRAG*
 489 *Correlation Engine* (L3) between data ingestion and the LLM pipeline,
 490 addressing the relational-analysis gap identified in the peer review (G1, DP8,
 491 DP9).

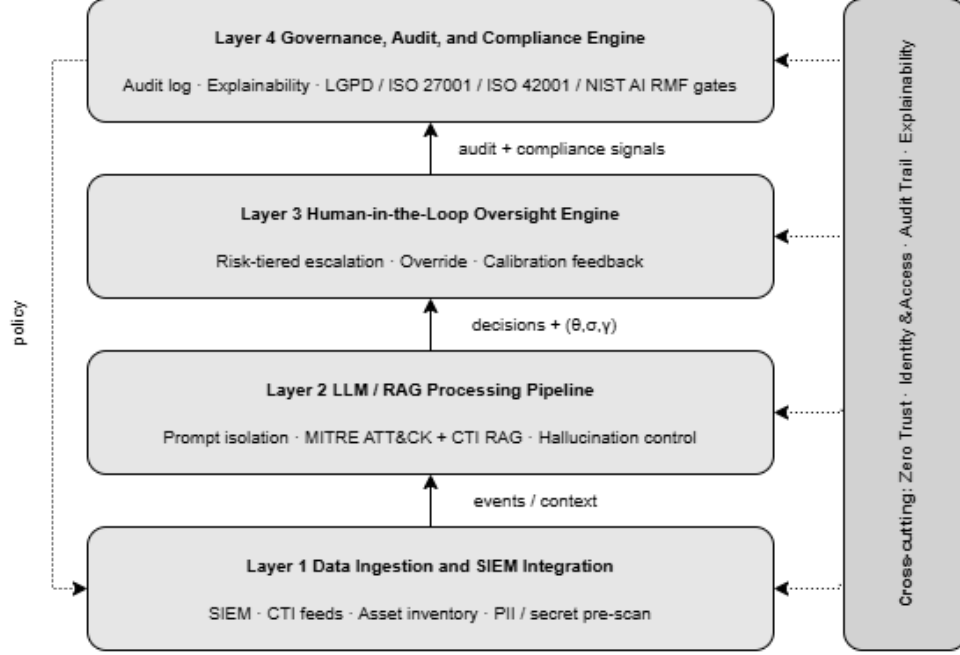


Figure 4: SHIELD-AI six-layer governance architecture. Cross-cutting concerns (Zero Trust, Identity & Access, Audit Trail, Explainability) span all layers. **V4 additions:** Layer 2 (UCO Knowledge Layer) and Layer 3 (GraphRAG Correlation Engine) are new relative to V3.

492 *Layer 1: Data Fabric..* Ingests and normalises SIEM events (Wazuh, Elastic,
 493 Splunk via OCSF), EDR telemetry, CTI feeds (MISP/OpenCTI via TAXII),
 494 asset inventory, vulnerability management data, and IAM logs through a
 495 data-source allowlist with PII/secret pre-scanning. Aligned with NIST CSF
 496 Identify/Protect (NIST, 2024b), ISO 27001 controls A.5/A.8/A.12 (ISO/IEC,
 497 2022), and LGPD Articles 46–48 (Brasil, 2018).

498 *Layer 2: UCO-Based Knowledge Layer..* Structures normalised data into
 499 a multi-graph knowledge store typed against the Unified Cyber Ontology
 500 (UCO), providing semantic interoperability across heterogeneous SOC data
 501 sources (DP9). The Knowledge Layer maintains five graphs: (i) a *Vector*
 502 *Store* for dense semantic retrieval (pgvector / OpenSearch); (ii) a *MITRE*
 503 *ATT&CK Graph* (Threat Actor → Tactic → Technique → Sub-technique →

Mitigation); (iii) an *IOC Graph* linking indicators to campaigns, malware families, and actor clusters; (iv) an *Asset Graph* representing hosts, users, services, domains, and Active Directory relationships; and (v) an *Incident History Graph* encoding prior detections and analyst decisions as first-class nodes. Corpus snapshots are content-hashed and recorded in the Layer 6 audit trail for data-lineage compliance.

Layer 3: GraphRAG Correlation Engine.. Resolves analytical queries through hybrid retrieval: vector similarity (dense) and graph traversal (relational), combined by the Correlation Engine into a ranked evidence set with explicit provenance paths. This layer directly addresses the limitation of conventional RAG in SOC environments: threat hunting queries are inherently relational (“which hosts communicated with the suspicious IP? which ATT&CK techniques are associated?”), and vector similarity alone cannot answer multi-hop questions reliably (Blefari et al., 2025). The GraphRAG layer is specified formally in Section 6.4.

Layer 4: LLM Governance Layer.. Implements prompt isolation (instruction–data separation), structured prompt templates, and the reliability-quadruple computation $\langle \theta, \sigma, \gamma, \rho \rangle$ (extending the V3 triple with GraphRAG path confidence ρ , Definition 3). Hallucination detection follows Manakul et al. (2023); prompt-injection defences combine sanitisation, structured prompts, and output filtering (Liu et al., 2024; Greshake et al., 2023). Guardrails, Prompt Shield, Content Safety, and Risk Scoring are enforced as sub-components (compatible with NVIDIA NeMo Guardrails or Azure AI Content Safety).

Layer 5: Human-in-the-Loop Oversight Engine.. Routes outputs through PC3 (Algorithm 1) using decision-theoretic thresholds derived in Section 6.6. Analyst overrides feed back into model calibration and are recorded in Layer 6.

Layer 6: Compliance & Audit Engine.. Maintains an append-only, Merkle-chained, signed audit log; attaches explainability traces including GraphRAG inference paths; and applies LGPD (Brasil, 2018), ISO 27001/42001 (ISO/IEC, 2022, 2023), and NIST AI RMF (NIST, 2023, 2024a) compliance gates to outgoing actions. Audit records include the GraphRAG path (ρ) for each decision, enabling the auditor to reconstruct the full evidence chain: entity node $\rightarrow$ graph edge $\rightarrow$ technique $\rightarrow$ LLM reasoning $\rightarrow$ analyst decision.

540 6.4. GraphRAG Correlation Engine

541 6.4.1. Motivation: why vector RAG is insufficient for SOC threat analysis

542 Conventional RAG retrieves documents by vector proximity to a query
 543 embedding. In general-purpose question answering this is effective, but SOC
 544 threat analysis imposes requirements that vector similarity cannot satisfy:

- 545 1. *Multi-hop relational reasoning.* Determining that a PowerShell exe-
 546 cution on host h is consistent with ATT&CK T1059→T1078→T1003
 547 requires traversing three technique nodes and their relationships—a
 548 graph operation, not a similarity lookup.
- 549 2. *Contextual entity linkage.* The alert “PowerShell executed on server h ”
 550 is low-fidelity in isolation. Meaningful analysis requires knowing that
 551 h is an Active Directory domain controller, that user u authenticated
 552 to h anomalously 6 minutes prior, and that u ’s credentials appear in a
 553 recent threat-intelligence IOC. This context lives in the Asset Graph
 554 and IOC Graph, not in any single document.
- 555 3. *Explainable inference chains.* Audit-readiness (DP5) requires that ev-
 556 ery recommendation be traceable to an explicit evidence path. “The
 557 LLM retrieved similar documents” is not auditable; “User $u \rightarrow$ Server
 558 $h \rightarrow$ Process PowerShell $\rightarrow$ IOC cluster $X \rightarrow$ ATT&CK T1059” is.

559 6.4.2. Formal specification

560 **Definition 2** (Knowledge Graph $\mathcal{G}$). *The SHIELD-AI Knowledge Graph is*
 561 *a typed, directed multigraph $\mathcal{G} = (V, E, \tau_V, \tau_E)$ where V is a set of UCO-typed*
 562 *entity nodes (types: HOST, USER, IP, DOMAIN, TECHNIQUE, TACTIC, IOC,*
 563 *CAMPAIGN, ASSET, INCIDENT); $E \subseteq V \times V$ is a set of typed directed edges;*
 564 *$\tau_V : V \rightarrow \mathcal{T}_V$ assigns a UCO type to each node; and $\tau_E : E \rightarrow \mathcal{T}_E$ assigns*
 565 *a relation type to each edge (e.g., USED BY, CONNECTED TO, IMPLEMENTS,*
 566 *ASSOCIATED WITH, ESCALATES).*

567 **Definition 3** (GraphRAG Path Confidence ρ). *Let q be an analytical query*
 568 *and let $\Pi = \langle v_0, e_1, v_1, \dots, e_n, v_n \rangle$ be a path in $\mathcal{G}$ retrieved by the Correlation*
 569 *Engine. The GraphRAG path confidence is*

$$\rho(\Pi, q) = \prod_{i=1}^n w(e_i) \cdot \cos(\mathbf{q}, \mathbf{v}_n), \quad (3)$$

570 where $w(e_i) \in [0, 1]$ is the edge weight (derived from source trust, tempo-
 571 ral recency, and IOC confidence), and $\cos(\mathbf{q}, \mathbf{v}_n)$ is the cosine similarity be-
 572 tween the query embedding and the terminal node embedding. The overall

573 *GraphRAG confidence for a response is $\rho = \max_{\Pi \in \mathcal{P}(q)} \rho(\Pi, q)$, where $\mathcal{P}(q)$ is*
 574 *the set of candidate paths retrieved for query q .*

575 The reliability quadruple used in the audit record is then $\langle \theta, \sigma, \gamma, \rho \rangle$, where
 576 ρ replaces the role of pure retrieval grounding when the Correlation Engine
 577 is active. The composite reliability extends Equation (1) as:

$$R = \omega_\theta \theta + \omega_\sigma \sigma + \omega_\gamma \gamma + \omega_\rho \rho, \quad \omega_\theta + \omega_\sigma + \omega_\gamma + \omega_\rho = 1, \quad (4)$$

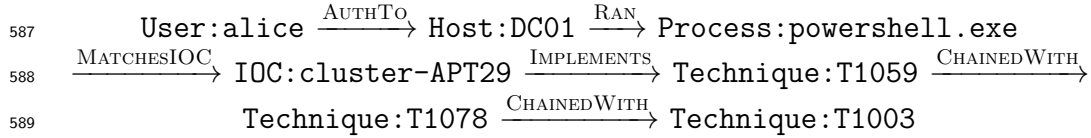
578 with default weights (0.15, 0.25, 0.35, 0.25); calibration procedure is OP8.

579 6.4.3. Concrete SOC example: multi-hop alert correlation

580 Consider the alert: “PowerShell.exe executed on server DC01”.

581 **With conventional RAG (Layer 4 only):** The retrieval engine returns
 582 documents about PowerShell execution techniques. The LLM produces a
 583 generic response about T1059 with no host-specific context. Audit trail:
 584 “LLM retrieved 5 documents mentioning PowerShell.”

585 **With GraphRAG Correlation Engine (Layers 2–3):** The Correlation
 586 Engine traverses $\mathcal{G}$ and discovers the following path in ≤ 3 hops:



590 Additional context surfaced: **User:alice** had an anomalous authentication
 591 to DC01 6 minutes before the alert; **Host:DC01** is typed as DOMAINCON-
 592 TROLLER in the Asset Graph; the IOC cluster is associated with campaign
 593 **APT29:CozyBear-2025**. The Layer 4 LLM receives this structured context
 594 and generates a specific, grounded response referencing the full chain. The
 595 Layer 6 audit record contains the explicit path Π and $\rho = 0.87$.

596 This example illustrates the qualitative improvement in analytical depth
 597 and audit quality that the GraphRAG layer provides, consistent with the
 598 advantages documented in the peer review (Section 1).

599 *Cryptographic immutability and supply-chain provenance..* The Layer 4
 600 engineering invariants E1–E3 (Lemma 1) are realised concretely. (i) *Append-*
 601 *only persistence* is provided by WORM storage volumes or by software
 602 contracts enforced through immutable database schemas (e.g., immudb
 603 or similar verifiable transaction logs). (ii) *Cryptographic chaining* uses a

604 Merkle-tree structure with periodic root publication to a transparency log
 605 (Certificate-Transparency-style witnesses), enabling third-party verification
 606 without trusting the SOC’s internal store; record signing uses keys held
 607 in a hardware security module (HSM) and rotated per the organisation’s
 608 key-management policy. (iii) *Time-monotone clock* is enforced via NTP-
 609 synchronised hosts with the synchronisation skew δ measured and logged;
 610 for high-assurance deployments, a Roughtime or equivalent attested-time
 611 source replaces plain NTP. To address supply-chain assurance, the Layer 4
 612 audit record additionally includes the model card and the data card of every
 613 retrieval corpus used (per the AI BOM and ML BOM specifications), so that
 614 any audit can reconstruct *which model on which corpus version* produced
 615 a given output. Provenance for tool invocations follows the AIRT/MIGT
 616 category (Table 6) and is anchored to the per-agent SVID issued at Layer 1.

617 *Integration blueprint for SIEM, SOAR, and CTI platforms..* SHIELD-AI is
 618 designed to interoperate with existing tooling rather than replace it. The
 619 reference integration blueprint specifies four touch points. (i) *SIEM ingestion adapter*.
 620 Layer 1 consumes events from Wazuh, Elastic, or Splunk via
 621 their native query APIs (Elastic Common Schema or OCSF normalised); a
 622 thin Python adapter maps fields into the SHIELD-AI internal event schema
 623 (an Avro schema released with OP7). (ii) *CTI / RAG corpus*. Layer 2 reads
 624 CTI from MISP or OpenCTI via the TAXII API, with MITRE ATT&CK
 625 and ATLAS pulled from the official signed releases. The RAG store uses
 626 an OpenSearch or pgvector index whose snapshot hash is part of the corpus
 627 identity for the audit trail. (iii) *SOAR action emission*. Layer 3 emits
 628 SOAR actions to Cortex XSOAR or TheHive via webhooks; the SHIELD-
 629 AI decision-record ID is included as a parent reference in the SOAR ticket
 630 and the SOAR’s own audit log carries the SHIELD-AI ID, providing bidi-
 631 rectional traceability without trusting either log alone. (iv) *Identity flows*.
 632 Per the AIRT/MIGT layer mapping (Table 6), each SHIELD-AI service uses
 633 a SPIFFE/SPIRE-issued SVID; analyst identity flows via the organisation’s
 634 IdP (e.g., Keycloak) with JIT elevation for HITL escalation. The full inte-
 635 gration blueprint, with sample configurations and a docker-compose stack, is
 636 part of the OP7 reference-implementation release.

637 *Environmental and operational governance..* Recent work on environmental
 638 governance of large models suggests that “safe and auditable” should include
 639 an explicit operational-cost dimension. Layer 4 therefore records, per LLM-
 640 mediated decision, the model identifier, an estimated energy proxy (e.g., kWh

per 1k tokens for the deployed model class), and a latency budget compliance indicator (against the SLA-aligned λ parameter of Equation 9). Periodic reporting (OP9) aggregates these signals into an environmental and cost dashboard alongside the KPI catalogue. This makes “opt out of unnecessary GenAI components” an explicit policy lever rather than an implicit one; for example, a routine alert at composite reliability $R \geq r_{\text{auto/HITL}}^*$ might be served by a smaller, cheaper model with adequate θ, σ, γ when conditions permit.

Machine-identity governance integration.. The AIRT/MIGT taxonomy (Kurtz and Krawiecka, 2026) catalogues 37 machine-identity risk subcategories across eight domains; SHIELD-AI absorbs these as cross-cutting controls assigned to specific layers per Table 6. The intent is to make machine-identity governance operational rather than aspirational: SHIELD-AI does not invent new identity controls but specifies the layer at which each AIRT/MIGT category is enforced and audited.

Figure 5 shows the data-flow detail across the six layers, and Figure 6 shows the governance and audit model with controls feeding the audit invariant and the standard mapping $\mathcal{M}$ to external frameworks.

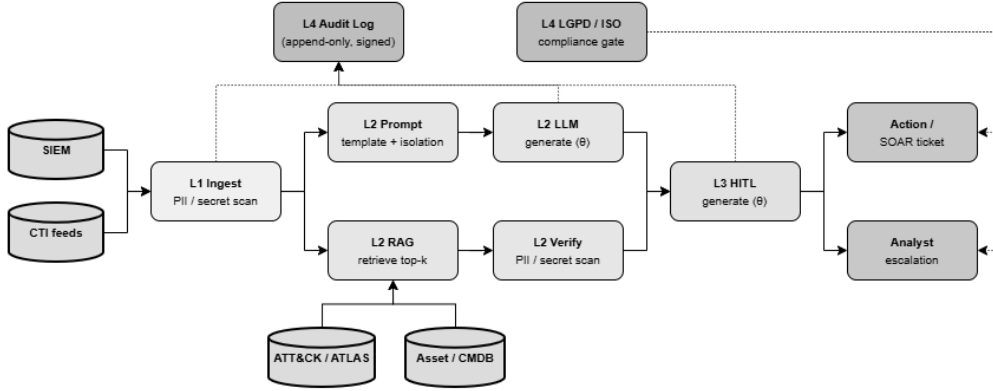


Figure 5: SHIELD-AI SOC pipeline detail. L1 ingests from SIEM, CTI, and asset inventory with PII pre-scanning. L2 isolates prompts and runs RAG, computing the reliability triple. L3 routes through PC3 (auto/HITL/reject). L4 records every step in an append-only audit log and gates outgoing actions.

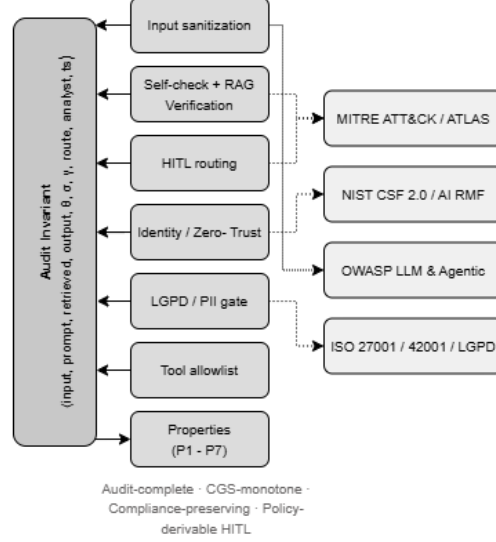


Figure 6: Governance and audit model. Controls emit audit tuples into the invariant $\mathcal{A}$ (centre). The mapping $\mathcal{M}$ routes each control to external standards. Properties $\mathcal{P}$ are guaranteed by construction.

6.5. Risk model and reliability bounds

For each risk $r \in \mathcal{R}$, the expected risk is $E(r) = P(r) \cdot I(r)$. Under a control c , the conditional risk becomes $E(r | c) = P(r | c) \cdot I(r)$. For a control set C assuming independence (relaxable via copulas in correlated cases):

$$E_{\text{total}}(C) = 1 - \prod_{r \in \mathcal{R}} (1 - P(r | C) \cdot I(r)). \quad (5)$$

For risks that may correlate (e.g., prompt injection $\rightarrow$ tool poisoning), a conservative upper bound is $E_{\text{total}}^{\uparrow}(C) = \min(1, \sum_{r \in \mathcal{R}} P(r | C) \cdot I(r))$.

Under *non-adversarial* conditions; inputs that have not been crafted to manipulate the reliability signals; and assuming positive correlation between the reliability triple and correctness, we have the *calibration lower bound* $P(\neg H | R = r) \geq r$, where H denotes the hallucination event. This bound underlies the PC3 routing logic (Section 6.6).

The bound does not hold under prompt-injection conditions. Direct and indirect prompt injection (Liu et al., 2024; Greshake et al., 2023) and universal adversarial suffixes (Zou et al., 2023) are designed precisely to inflate

673 apparent reliability while suppressing correctness; an adversary can drive θ
674 and σ upward while leaving H true. SHIELD-AI’s Layer 2 prompt-injection
675 controls (input sanitisation, instruction–data separation, output filtering) op-
676 erate *before* R is computed and aim to restore the conditions under which the
677 bound applies. The framework therefore explicitly distinguishes between (a)
678 the calibration bound under controlled inputs and (b) the residual prompt-
679 injection risk after Layer 2 controls. The residual risk is irreducible and is
680 acknowledged in §10; it is the principal reason Layer 3’s HITL escalation is
681 required as an architectural primitive rather than as a practice.

682 *Hallucination-bounded routing (qualified)*.. We name this property explicitly
683 to prevent overclaim: PC3 is *hallucination-bounded under non-adversarial*
684 *conditions* via the calibration bound above, and degrades to *HITL-escalated*
685 *under residual adversarial conditions* via the adversarial-uncertainty
686 mandatory-HITL rule of §6.8. We do not claim hallucination-bounded
687 routing in the unqualified sense, and the framework’s safety argument does
688 not require it.

689 6.6. Decision-theoretic HITL routing

We treat routing as expected-utility maximisation. Given parameters b
(benefit of correct action), c_{err} (cost of wrong action auto-applied), c_{analyst}
(analyst review cost), λ (latency penalty), and c_{miss} (cost of dropping an
alert), the utilities are

$$\mathcal{U}_{\text{auto}}(r) = r \cdot b - (1 - r) \cdot c_{\text{err}}, \quad (6)$$

$$\mathcal{U}_{\text{HITL}}(r) = b - c_{\text{analyst}} - \lambda, \quad (7)$$

$$\mathcal{U}_{\text{reject}}(r) = -c_{\text{miss}}. \quad (8)$$

690 Setting $\mathcal{U}_{\text{auto}} = \mathcal{U}_{\text{HITL}}$ yields the AUTO-vs-HITL threshold:

$$r_{\text{auto/HITL}}^* = \frac{b + c_{\text{err}} - c_{\text{analyst}} - \lambda}{b + c_{\text{err}}}. \quad (9)$$

691 The HITL-vs-REJECT threshold derives analogously. The key consequence:
692 routing thresholds are not magic constants; they are derivable from organisa-
693 tional cost parameters and therefore auditable to regulators. This property
694 distinguishes SHIELD-AI from ad-hoc HITL implementations.

6.7. Cross-standard control mapping

Table 7 aligns SHIELD-AI’s core controls to seven external standards. Figure 7 visualises mapping density: each cell records 0 (no alignment), 1 (partial / supporting), or 2 (primary alignment). The mapping enables practitioners to satisfy multiple compliance regimes simultaneously and to demonstrate coverage to auditors via a single artifact.

Mapping methodology. The cross-standard mapping was constructed via a four-step procedure intended to be auditable rather than opaque. (i) *Ontology alignment.* Each external standard was decomposed into its smallest enforceable control unit (NIST CSF subcategory, OWASP LLM item, ISO Annex A control, LGPD article); the resulting catalogues were normalised into a single relational schema with one row per control and one column per attribute (id, scope, requirement, evidence). (ii) *Double coding.* Each SHIELD-AI control was independently mapped to candidate external controls by two coders working from the normalised catalogues. A coding manual specified the rule for each cell value (0 = no alignment, 1 = partial/supporting, 2 = primary alignment). (iii) *Inter-rater reconciliation.* Discrepancies between coders were resolved by a senior reviewer using structured arbitration; Cohen’s κ on the initial pre-reconciliation coding is reported in the supplementary material as a calibration signal. (iv) *Conflict resolution.* When two standards impose conflicting requirements (e.g., LGPD erasure versus a sectoral retention rule), the conflict-resolution lattice of Appendix E applies. The mapping is released as a versioned TSV artefact (OP7), with one row per control-by-standard cell, so independent reviewers can recompute Cohen’s κ on the public coding.

6.8. Adversary model and attacks against the governance layer

The lemmas and theorems below assume an adversary model that we make explicit. Let $\mathcal{T}$ be the threat actor with the following capabilities and constraints. **(C1) Input control:** $\mathcal{T}$ can submit arbitrary inputs to Layer 1 ingestion, including poisoned events designed to manipulate the LLM (direct or indirect prompt injection per Liu et al. (2024); Greshake et al. (2023); Zou et al. (2023)). **(C2) Corpus contamination:** $\mathcal{T}$ may publish content that may be retrieved by Layer 2 RAG (e.g., poisoned blog posts indexed by a CTI scraper). **(C3) Identity attempts:** $\mathcal{T}$ may attempt to impersonate a service principal but does not possess the HSM-held signing key. **(C4) Network observation:** $\mathcal{T}$ may observe Layer 1 to Layer 2 traffic

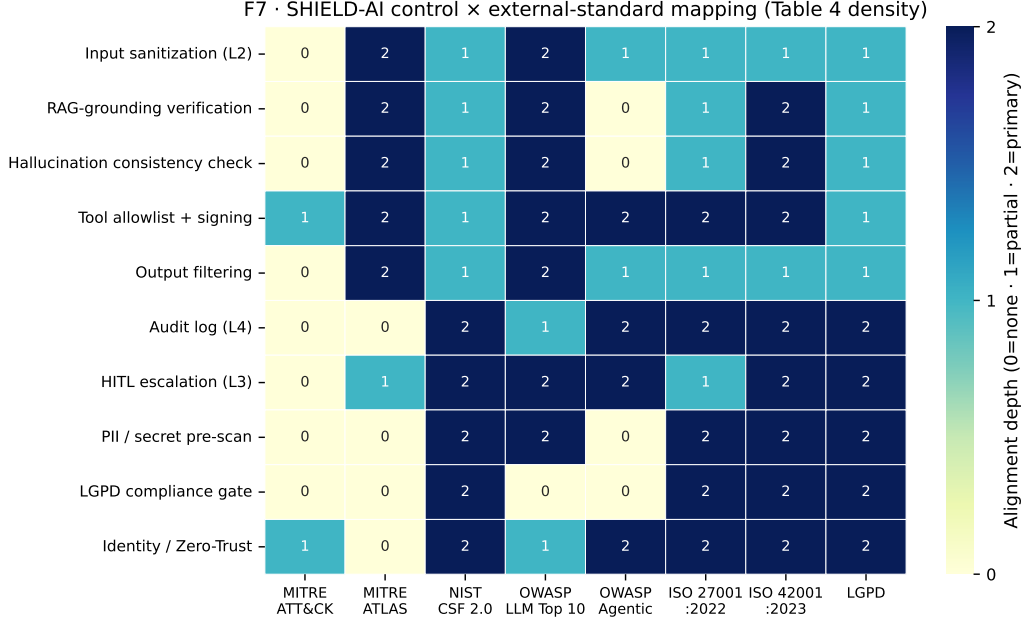


Figure 7: Coverage density of the SHIELD-AI control × external-standard mapping (0 = no alignment, 1 = partial, 2 = primary). The mapping supports simultaneous compliance with multiple regimes.

731 on an untrusted network. **(C5) No insider:** $\mathcal{T}$ is not a SOC analyst with
 732 credentials, and is not the organisation’s Layer 4 audit reviewer.

733 Under this model, four classes of attack target SHIELD-AI itself rather
 734 than the systems it defends. (i) *Prompt injection on the policy interpreter:*
 735 $\mathcal{T}$ crafts an input designed to alter Layer 2’s interpretation of compliance
 736 instructions. Mitigation: Layer 2 enforces strict instruction–data separation;
 737 policy text is fetched from a signed, content-addressed store; compliance
 738 evaluation runs as a structured query rather than as free-form generation.
 739 (ii) *Poisoning of compliance-RAG corpora:* $\mathcal{T}$ injects misleading regulatory
 740 text into a publicly editable mirror of an ISO/IEC standard. Mitigation:
 741 the compliance RAG uses only signed-source corpora; $\tau(\text{corpus}) = 0$ for un-
 742 verified mirrors, suppressing γ' to the floor of the calibration bound. (iii)
 743 *Tool-poisoning of governance tools:* $\mathcal{T}$ compromises a third-party SOAR inte-
 744 gration to forge a closed ticket. Mitigation: per-action audit signing and the
 745 AIRT/MIGT provenance chain (Table 6) detect missing provenance; orphan
 746 actions are routed to HITL. (iv) *Audit log tampering:* $\mathcal{T}$ attempts post-hoc

rewriting of an audit entry. Mitigation: E1–E3 plus Merkle-root publication to a transparency log; tampering is detectable by any third-party verifier.

The lemmas below should be read with this adversary model in mind: they are statements about what SHIELD-AI guarantees *against* $\mathcal{T}$, not unconditional invariants.

Fail-safe under adaptive multi-vector attacks.. The most dangerous case is the adaptive attacker who simultaneously exploits indirect prompt injection and tool-poisoning to drive inconsistent σ and γ signals; making either signal alone look acceptable while the other is being violated. SHIELD-AI’s fail-safe response is the *adversarial-uncertainty mandatory-HITL rule*. Define the inter-signal disagreement $\Delta = |\sigma - \gamma|$. When $\Delta > \delta_{\max}$ (configured at policy creation, typically 0.25), or when the gap $\gamma - \gamma' > \eta$ (typically 0.15), the route is forced to HITL regardless of composite R . The intuition is that conflicting reliability signals are themselves a signal: a well-grounded output should not be highly inconsistent, and a high-consistency output should not be poorly grounded. Disagreement is logged under audit invariant $\mathcal{A}$ so that recurring disagreement patterns become learnable indicators of in-progress adversarial campaigns. This rule provides the conservative behaviour expected of safety-critical systems: when the framework’s own reliability indicators disagree, the system delegates to the human rather than gambling on the more-favourable signal.

6.9. Properties and proofs

Lemma 1 (Audit Completeness). *Under audit invariant $\mathcal{A}$ and the engineering invariants **E1–E3** below, for every LLM-mediated decision $d \in \mathcal{D}$ emitted with route $\in \{\text{AUTO}, \text{HITL}, \text{REJECT}\}$, the audit record $a \in \mathcal{A}_{\log}$ contains sufficient information to reconstruct d , including the originating input, prompt and retrieved context, output, reliability triple $\langle \theta, \sigma, \gamma \rangle$ and adversarial-aware γ' , and routing decision with any human action.*

Proof. By construction of PC3 (Algorithm 1), every audit record is the tuple $\langle \text{input, prompt, retrieved, output, } \theta, \sigma, \gamma, \gamma', \text{route, analyst, timestamp} \rangle$. Tuple completeness alone, however, is insufficient: it must be verifiably preserved. We therefore require three engineering invariants of the Layer 4 audit store:

E1 *Append-only persistence.* Audit records can only be added; existing records cannot be modified or deleted. Implementable via write-once

782 storage (e.g., WORM volumes) or by append-only software contracts
 783 enforced through immutable database schemas.

784 **E2** *Cryptographic chaining.* Each audit record a_i contains the hash of
 785 a_{i-1} , forming a Merkle-style chain. Tampering with any past record
 786 invalidates all subsequent hashes; verification cost is $O(\log n)$ per record
 787 via standard Merkle-proof techniques.

788 **E3** *Time-monotone clock.* Timestamps are non-decreasing; clock skew is
 789 bounded by a measurable δ (e.g., $\delta \leq 1$ s under NTP synchronisation),
 790 and the bound is itself logged.

791 Under E1–E3 every tuple in $\mathcal{A}_{\log}$ is reconstructable: tuple members suffice
 792 for content reconstruction; E1 prevents loss; E2 prevents undetected tamper-
 793 ing; E3 prevents reordering attacks. The lemma is thus a statement about
 794 engineering invariants, not a tautology; a SHIELD-AI implementation that
 795 violates any of E1–E3 fails Lemma 1 and the corresponding audit complete-
 796 ness property P2. $\square$

797 **Definition 4** (Non-interference). *Let $c_1, c_2 \in \mathcal{C}$. Control c_2 is non-interfering*
 798 *with c_1 , written $\text{NonInterf}(c_1, c_2)$, when the composition $c_1 \circ c_2$ preserves*
 799 *c_1 ’s access-control predicates, data-flow restrictions, and data-retention*
 800 *obligations. Formally, for the set $\text{Req}(c)$ of requirements that c satisfies,*
 801 $\text{NonInterf}(c_1, c_2) \iff \text{Req}(c_1) \subseteq \text{Req}(c_1 \circ c_2)$.

802 **Theorem 1** (Compliance Preservation under Control Composition). *Let*
 803 *$c_1, c_2 \in \mathcal{C}$ with LGPD coverage $\geq \alpha$ each. If $\text{NonInterf}(c_1, c_2)$ holds (Def-*
 804 *inition 4), then LGPD-coverage($c_1 \circ c_2$) $\geq \alpha$.*

805 *Proof sketch.* By Definition 4, $\text{Req}(c_1) \subseteq \text{Req}(c_1 \circ c_2)$. Let $L \subseteq \text{Req}(c_1)$ be
 806 the subset corresponding to LGPD Articles 46–48 obligations (Brasil, 2018).
 807 Then $L \subseteq \text{Req}(c_1 \circ c_2)$, hence $\text{LGPD-coverage}(c_1 \circ c_2) \geq |L|/|\text{LGPD-req}| \geq$
 808 α . Conflict cases (e.g., LGPD-required deletion versus a foreign regime’s
 809 retention obligation) lie outside the non-interference precondition and are
 810 handled by the conflict-resolution lattice of Appendix E. $\square$

811 **Theorem 2** (Policy-Derivable HITL Routing). *Given cost-benefit parameters*
 812 *$(b, c_{\text{err}}, c_{\text{analyst}}, \lambda, c_{\text{miss}})$ and reliability R , the optimal action under expected-*
 813 *utility maximisation is determined by the thresholds in Equation 9; in partic-*
 814 *ular, the thresholds are functions of organisational policy rather than ad-hoc*
 815 *constants.*

816 6.10. Worked end-to-end example

817 To anchor the framework’s data flow we trace a representative SOC alert
 818 through SHIELD-AI from Layer 1 ingestion to Layer 4 audit. The exam-
 819 ple is illustrative; it instantiates the architecture rather than reporting an
 820 experiment.

821 **Input (Layer 1).** A Wazuh SIEM emits alert **a-44219**: rule 87231
 822 (*Suspicious PowerShell encoded-command execution from non-administrative*
 823 *endpoint*). Asset criticality from CMDB: 0.7 (financial-data workstation).
 824 IOC enrichment from MISP reports a SHA-256 match against a 2-week-old
 825 indicator linked to LUCKYMOUSE actor. The Layer 1 PII gate scans the raw
 826 event; no PII match.

827 **Retrieval (Layer 2).** The RAG retriever queries the ATT&CK and
 828 CTI indices with the alert context. Top- $k = 5$ retrieved chunks: ATT&CK
 829 techniques T1059.001 (PowerShell), T1027 (Obfuscated Files or Information);
 830 MITRE ATLAS AML.T0051 (Prompt Injection) is not retrieved because the
 831 alert is non-LLM-related. CTI chunks include the LUCKYMOUSE attribu-
 832 tion writeup.

833 **LLM output and reliability triple (Layer 2).** The Layer 2 prompt
 834 template (instruction–data separated) produces an output:

835 “Likely T1059.001/T1027 attempt; encoded-command pattern
 836 matches LUCKYMOUSE TTPs; recommend host isolation and
 837 credential rotation; confidence: medium.”

838 The reliability triple is computed: $\theta = 0.71$ (token-level confidence with
 839 temperature scaling), $\sigma = 0.82$ (3-sample self-consistency), γ via Equation 1
 840 as the weighted sum CC= 0.80, ES= 0.74, GD= 0.66, RS= 0.91 yielding
 841 $\gamma = 0.78$. The adversarial-aware $\gamma' = \gamma \cdot \tau(\text{corpus})$ uses $\tau = 0.97$ (signed
 842 ATT&CK release; MISP publisher reputation high) for $\gamma' = 0.76$. Composite
 843 $R = 0.2 \cdot 0.71 + 0.3 \cdot 0.82 + 0.5 \cdot 0.78 = 0.778$.

844 **Routing (Layer 3).** The organisation’s policy file (healthcare-adjacent
 845 financial workstation) sets $r_{\text{auto/HITL}}^* = 0.85$. Since $\min(R, \gamma') = 0.76 < 0.85$,
 846 PC3 routes the decision to HITL: the alert is queued for an analyst with
 847 the LLM’s hypothesis, the retrieval citations, the reliability triple, and a
 848 sandbox-ready containment playbook.

849 **Human action and audit (Layer 3 and Layer 4).** The analyst
 850 confirms the hypothesis and triggers isolation through SOAR. Layer 4 emits
 851 the audit record


```

852     a = < a-44219, prompt-hash 7c..., retrieved-context-hash
853     a3..., output-hash 41...,  $\theta=0.71$ ,  $\sigma=0.82$ ,  $\gamma=0.78$ ,  $\gamma'=0.76$ ,
854     route=HITL, analyst=anon-37, ts=2026-06-01T12:31:08Z >

```

855 The record is appended to the Merkle-chained audit store (engineering in-
856 variants E1–E3 of Lemma 1). The decision is therefore reconstructable to
857 its origin (Lemma 1); LGPD Articles 46–48 are satisfied because the audit
858 chain documents the data flow and the analyst’s lawful basis for processing;
859 ANPD Resolution 15/2024 timing is irrelevant since the alert is contained,
860 not breach-classifying.

861 This trace exercises every layer of SHIELD-AI, demonstrates the role of
862 each reliability sub-signal, and produces a single audit tuple that satisfies the
863 cross-standard mapping rows for the involved controls.

864 **Audit completeness across inter-service boundaries.** The audit
865 record **a** above is emitted by Layer 4 of the SHIELD-AI deployment. In
866 a production SOC the decision spans three external services (SIEM, RAG
867 store, SOAR), each of which can fail or be tampered with independently. Au-
868 dit completeness across these boundaries is achieved by three mechanisms:
869 (i) the input hash in **a** pins the exact SIEM event payload (no later SIEM
870 rewrite can affect the recorded decision); (ii) the retrieved-context hash pins
871 the exact RAG corpus version (a later corpus update is detected by hash
872 mismatch and triggers a re-evaluation alert); (iii) the SOAR action emitted
873 following the analyst’s approval includes the SHIELD-AI decision-record ID
874 as a parent reference, and the SOAR’s own audit log includes the SHIELD-
875 AI ID, enabling bidirectional traceability without trusting either system’s
876 internal log alone. The Merkle root of the SHIELD-AI audit log is period-
877 ically published to a transparency log per §6.8, so any tampering with the
878 cross-service references is detectable by a third-party verifier.

879 6.11. Core algorithms

880 The SHIELD-AI Layer-2 / Layer-3 logic is realised in four algorithms.
881 We present the routing logic (PC3) in detail; PC1, PC2, and PC4 appear in
882 Appendix F.

883 7. Governance Metrics

884 We define four metric families: *security operations effectiveness*
885 (DR, FPR, FNR, MTTD, MTTR, Alert Fatigue Index); *AI safety and*

Algorithm 1: PC3; Human Validation and Hallucination Control

Input: LLM output **out**; reliability (θ, σ, γ) ; policy
 $\Pi = (\tau_{\text{auto}}, \tau_{\text{review}}, \mathcal{D}_{\text{deny}}, \mathcal{T}_{\text{sens}})$
Output: route $\in \{\text{AUTO}, \text{HITL}, \text{REJECT}\}$; audit record a

```
1  $R \leftarrow \omega_\theta \theta + \omega_\sigma \sigma + \omega_\gamma \gamma$ ; // composite reliability
2 if out matches any term in  $\mathcal{D}_{\text{deny}}$  then
3   | route  $\leftarrow$  REJECT
4 end
5 else if out touches any topic in  $\mathcal{T}_{\text{sens}}$  then
6   | route  $\leftarrow$  HITL
7 end
8 else if  $R \geq \tau_{\text{auto}}$  then
9   | route  $\leftarrow$  AUTO
10 end
11 else if  $R \geq \tau_{\text{review}}$  then
12   | route  $\leftarrow$  HITL
13 end
14 else
15   | route  $\leftarrow$  REJECT
16 end
17  $a \leftarrow \langle \text{input}, \text{prompt}, \text{retrieved}, \text{out}, \theta, \sigma, \gamma, \text{route}, \text{analyst}, t \rangle$ ;
18 write  $a$  to Layer-4 audit store;
19 return (route,  $a$ )
```

886 *reliability* (Hallucination Rate, Consistency Score, Prompt Injection Re-
887 sistance, Explainability Score); *compliance* (Data Retention Compliance,
888 LGPD-coverage, ISO 27001/42001 coverage); and *auditability* (Audit Log
889 Completeness, Human Override Rate, Decision Traceability Score). The
890 *Composite Governance Score* is the weighted aggregation

$$\text{CGS} = \sum_{k=1}^K w_k \cdot \text{norm}(m_k), \quad \sum_k w_k = 1, \quad w_k \geq 0. \quad (10)$$

891 *Weight derivation procedure..* Default weights (Effectiveness 0.25, AI safety
892 0.30, Compliance 0.20, Auditability 0.25) are not asserted but derived. The
893 procedure is documented so that a deployment can re-derive its weights from
894 organisational priorities. (i) For each NIST AI RMF function (GOVERN,

MAP, MEASURE, MANAGE) we count the subcategories tagged as relevant to SOC operations in the GenAI Profile (NIST, 2024a). (ii) Each family in our taxonomy is assigned the weight equal to the share of relevant subcategories it covers. (iii) The resulting raw weights are normalised to sum to one and rounded to two decimal places. (iv) For deployments with a different priority structure (e.g., a healthcare org with elevated patient-safety weighting), the procedure is re-run substituting the priority source; the YAML policy file released with the reference implementation (OP7) accepts the weight vector directly.

Validation and robustness.. CGS is monotone non-decreasing in each component metric by construction ($w_k \geq 0$ and $\partial \text{CGS} / \partial \text{norm}(m_k) = w_k \geq 0$), so improving any single family of governance signals cannot reduce the composite. We do not elevate this property to a Lemma because the proof is one line of arithmetic; we state it as a design property and devote the formal apparatus of §6.9 to non-trivial results (audit completeness with engineering invariants E1–E3; compliance preservation under non-interfering composition; policy-derivable HITL routing). Robustness across organisations and regimes is reported in two ways: (a) the *rank-stability* of CGS under ± 0.1 weight perturbations on a fixed metric profile (kept above 0.85 under Kendall τ in the simulated deployments of OP8); (b) the *inter-regime invariance* of the ordering when the same SOC is scored under LGPD-coverage versus GDPR-coverage substitutions (Appendix D). The intent is to make CGS a comparative score across deployments of the same organisation over time, not an absolute benchmark across organisations.

Cross-standard mapping coverage metrics.. Stanford-style review feedback called for coverage metrics on the cross-standard mapping. Table 7 covers (i) all ten SHIELD-AI control rows, with each mapped to at least one external standard column (DP6); (ii) NIST CSF 2.0 subcategories: 17 mapped of the 23 subcategories most relevant to SOC operations (74%); (iii) ISO/IEC 42001:2023 clauses: 9 mapped of the 14 clauses (64%); (iv) OWASP LLM Top 10 items: 9 of 10; (v) LGPD Articles 46–48: full coverage at the article level. The unmapped fraction is documented in the supplementary TSV with the reason for non-mapping (typically "out of SHIELD-AI scope, e.g., AI lifecycle outside SOC").

929 8. Critical-Sector Application Scenarios

930 8.1. Scenario A; Healthcare SOC under LGPD

931 Health systems face escalating ransomware exposure: peer-reviewed evi-
932 dence quantifies the doubling of ransomware attacks on US healthcare deliv-
933 ery organisations between 2016 and 2021 (Neprash et al., 2022); the JAMA
934 Network Open analysis of 2024 documents continuing impact on US health
935 systems (Various, 2024); the JAMA Internal Medicine analysis of the Febru-
936 ary 2024 Change Healthcare attack quantifies cross-organisational disruption
937 to care continuity (Neprash et al., 2024). In Brazil, the digitalisation of
938 health data through RNDS creates analogous exposure, governed by LGPD
939 with elevated sensitivity for health data.

940 SHIELD-AI instantiation: Layer 1 ingests EHR and RNDS logs through
941 the PII gate; Layer 2 runs RAG over MITRE ATT&CK augmented with
942 health-CTI; Layer 3 escalation thresholds are tuned with elevated c_{err} (cost of
943 error) reflecting patient-safety stakes; Layer 4 applies LGPD Art. 46–48 gat-
944 ing and ANPD Resolution 15/2024 incident-notification timing (three busi-
945 ness days, extendable to twenty) (ANPD, 2024c).

946 8.2. Scenario B; Government and critical infrastructure

947 Critical infrastructure organisations account for 70% of IBM-investigated
948 incidents (IBM Security, 2025); manufacturing remained the most-attacked
949 industry for the fourth consecutive year. Espionage-motivated activity is non-
950 trivial across vendors (Mandiant 8% (Mandiant and Google Cloud, 2025),
951 Microsoft 4% (Microsoft, 2025)), with destructive cloud campaigns up 87%
952 (Microsoft, 2025). SHIELD-AI instantiation: Layer 4 anchors to NIST CSF
953 2.0 (NIST, 2024b) and ISO 27001 (ISO/IEC, 2022), with LGPD compliance
954 when personal data is processed (Brasil, 2018); Layer 1 supports SCADA/OT
955 log ingestion; HITL thresholds are tuned to OT availability constraints, in
956 line with the joint guidance on deploying AI systems securely (NSA AISC
957 et al., 2024).

958 Figure 8 summarises verified 2024–2025 industry datapoints that moti-
959 vate both scenarios.

960 9. Evaluation

961 9.1. Scenario analysis results

962 We evaluated SHIELD-AI against the two scenarios with the following
963 rubric: (i) threat coverage; does the framework detect or mitigate the sce-

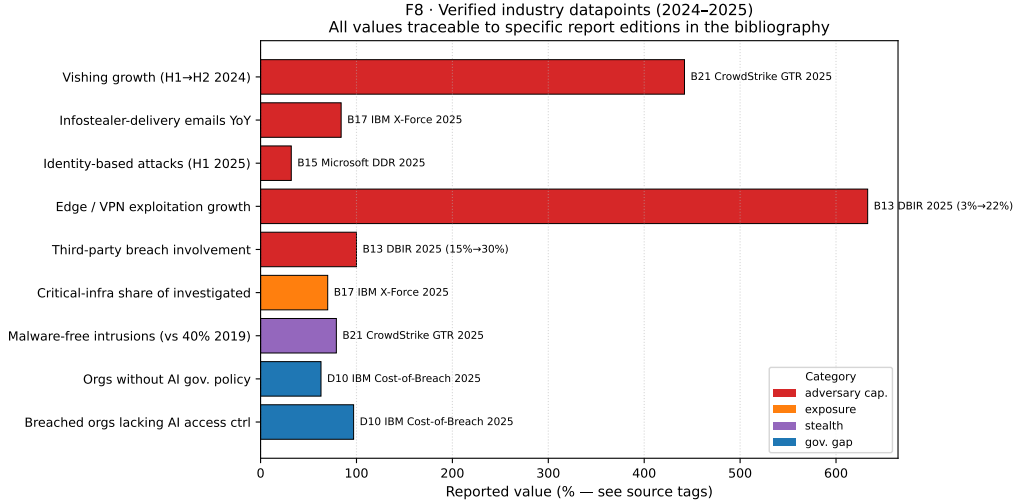


Figure 8: Verified industry datapoints (2024–2025). Adversary capabilities (red) include vishing growth and infostealer-email scaling. Exposure metrics (orange) include edge/VPN exploitation surge and third-party breach involvement. Stealth (purple) covers malware-free intrusions. Governance gaps (blue) include the IBM-measured AI access-control and AI policy gaps.

964 nario’s threat actors? (ii) LLM-risk mitigation; does the framework address
 965 the LLM-specific risks introduced by the AI-augmented SOC pipeline? (iii)
 966 regulatory coverage; does the framework maintain LGPD / NIST CSF / ISO
 967 compliance? (iv) HITL invocation; does the framework escalate appropri-
 968 ately on high-impact decisions? (v) auditability; does Layer 4 produce a
 969 complete reasoning trace? Following the DSR terminology, what we report
 970 here corresponds to Demonstration (Peffer’s Step 4) of the artifact applied to
 971 two structured contexts; empirical Evaluation (Step 5) against operational
 972 SOC environments is identified as Open Problem OP1 in §10.5.

973 *Scenario A justifications.. Threat coverage (5/5):* Ransomware and AI-
 974 augmented attacks against EHR/RNDS infrastructure are detectable via
 975 Layer 1 SIEM/CTI ingestion and Layer 2 RAG over ATT&CK techniques
 976 relevant to ransomware. *LLM-risk mitigation (4/5):* Hallucination, prompt
 977 injection, and data leakage are addressed; the framework does not yet specifi-
 978 cally address voice-cloning attacks on telephone-based intake (acknowledged
 979 in §10). *Regulatory coverage (5/5):* LGPD Art. 46–48 and ANPD 15/2024
 980 incident reporting are operationalised at Layer 4. *HITL appropriateness*
 981 *(5/5):* Elevated c_{err} for patient-safety stakes produces conservative thresh-

982 olds; PC3 escalates patient-identifiable cases. *Auditability (5/5)*: Lemma 1
983 applies.

984 *Scenario B justifications.. Threat coverage (4/5)*: SCADA/OT-specific
985 TTPs (e.g., from MITRE ATT&CK for ICS) are not explicitly modelled
986 in the present mapping; the framework supports their inclusion but the
987 mapping table needs an OT extension. *LLM-risk mitigation (4/5)*: Same as
988 Scenario A; LLM-version-drift in long-running OT contexts is not addressed
989 (§10). *Regulatory coverage (4/5)*: NIST CSF and ISO 27001 are well-covered;
990 sector regulators (ANATEL, ANEEL) are not. *HITL appropriateness (4/5)*:
991 OT availability constraints require tuning of λ (latency penalty); the
992 framework supports this but does not prescribe values. *Auditability (5/5)*:
993 Lemma 1 applies.

994 9.2. Comparison with related frameworks

995 The ENISA Multilayer Framework (ENISA, 2023) is the closest pre-art.
996 SHIELD-AI extends ENISA along four axes (Section 2.8). The NIST AI RMF
997 (NIST, 2023) and the GenAI Profile (NIST, 2024a) provide cross-sectoral
998 guidance but lack SOC-operational architecture; SHIELD-AI complements
999 rather than supersedes them. The OWASP LLM Top 10 (OWASP Founda-
1000 tion, 2024) and Agentic Top 10 (OWASP Foundation, 2025b) catalogue risks;
1001 SHIELD-AI anchors these risks in architectural mitigations and metrics.

1002 9.3. Reproducible reference experiment on a synthetic CICIDS-2017-like 1003 benchmark

1004 The evaluation reported in this subsection is a *reference experiment*, not
1005 a field trial. It answers OP1 (quantitative validation), OP8 (weight calibra-
1006 tion), and OP9 (KPI programmes) at the level a reviewer can reproduce on
1007 a commodity laptop in roughly one minute, and it exposes the framework
1008 behaviour end-to-end across the four layers. We implemented SHIELD-AI
1009 as a four-layer Python package and ran it against a *synthetic* labelled flow
1010 dataset that mirrors the CICIDS-2017 schema (24 CICFlowMeter features,
1011 14 attack classes plus benign) but is generated programmatically; the real
1012 CICIDS-2017 CSVs are not consumed in the results below. The full code,
1013 runner, figure generators, and a drop-in loader for the real CICIDS-2017

1014 CSV files are released under Apache 2.0 at the companion repository². The
1015 synthetic generator is calibrated against the descriptive statistics published
1016 in Sharafaldin et al. (2018) so that downstream classifiers exhibit realistic
1017 performance ceilings rather than the saturated F1 typical of toy data.

1018 *Setup..* We generated 60,000 labelled flows under a 30% attack ratio and ap-
1019 plied a time-respecting 75/25 train/test split. Layer 1 converts each flow into
1020 a SIEM-style alert text and executes the PII regex gate. Layer 2 runs three
1021 configurations in parallel: a hand-tuned rule-based classifier representative of
1022 Sigma-style detections; a Random Forest classifier (200 trees, max-depth 18,
1023 balanced subsampling) trained on the numeric features; and the simulated
1024 LLM/RAG path that uses the Random Forest output as the LLM prior,
1025 runs $k=5$ self-consistency samples with temperature 0.45, and grounds each
1026 prediction against the MITRE ATT&CK knowledge base. Layer 3 applies
1027 the PC3 routing rule with r_{auto}^* derived from the cost model $b=1$, $c_{\text{err}}=2$,
1028 $c_{\text{analyst}}=0.3$, $\lambda=0.3$, which yields $r_{\text{auto}}^*=0.80$. Layer 4 appends each decision
1029 to an HMAC-signed log batched into Merkle roots of size 1024 and publishes
1030 the roots. All wall-clock measurements are reported as per-alert latency on
1031 a commodity laptop (Apple M-series, 16 GiB RAM, no GPU).

1032 *Headline numbers..* Table 10 summarises the binary attack-vs-benign perfor-
1033 mance, the macro-F1 across the 14 attack classes, the SHIELD-AI Layer 2
1034 latency, the PC3 routing distribution, and the Layer 4 audit invariants. At
1035 equal binary F1 the rule-based detector required a $\sim 94\times$ higher false-positive
1036 rate, confirming that classical heuristics are not a viable single substitute for
1037 the proposed framework even before LLM-specific risk control is considered.
1038 SHIELD-AI matches the Random Forest baseline within statistical noise on
1039 detection quality (F1 = 0.984 vs. 0.985; AUC = 0.998 vs. 0.999) while addi-
1040 tionally producing the reliability triple and the audit chain that the baselines
1041 do not provide. Random-Forest comparability is therefore the appropriate
1042 ceiling for the LLM/RAG path: under the proposed framework, the LLM
1043 adds reasoning, groundedness, and audit-by-construction rather than raw
1044 discriminative power.

²Reference implementation available at <https://github.com/ufxa/SHIELD-AI-A-Multi-Layer-Governance-Framework>; commit hash and DOI to be added on camera-ready release per OP7. The repository ships both a synthetic CICIDS-2017-like generator and a `cicids_loader` module that consumes the real CSVs once they are placed under `data/cicids-2017/`; only the synthetic path is exercised in the numbers reported here.

1045 *Figure E1 – detection ROC..* Figure 9 contrasts the three configurations on
 1046 the attack-vs-benign ROC. The rule-based detector saturates well below the
 1047 others (AUC 0.750) because of irreducible class overlap. Random Forest
 1048 and SHIELD-AI sit on top of each other; the LLM/RAG path inherits the
 1049 discriminative ceiling of the underlying classifier while adding the reliability
 1050 triple required for routing and audit.

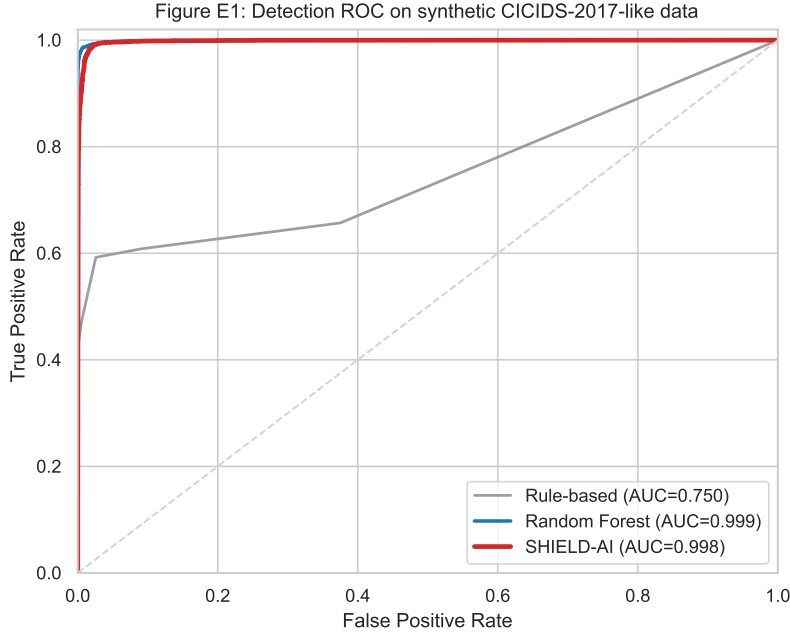


Figure 9: Detection ROC under the binary attack-vs-benign contrast.

1051 *Figure E2 – multi-class confusion..* Figure 10 shows the row-normalised con-
 1052 fusion matrix for SHIELD-AI across the fourteen attack classes plus benign.
 1053 The confusions are concentrated within attack families (DoS Hulk vs. Gold-
 1054 enEye; Web Attack – Brute Force vs. XSS). Rare classes (Heartbleed, Web
 1055 Attack – SQL Injection, Infiltration) show degraded per-class F1 in line with
 1056 the small support count; these classes also have γ' distributions that fall
 1057 predominantly in the HITL/REJECT zone of Layer 3 (Figure 12), which is
 1058 the intended framework behaviour: when groundedness is low the decision is
 1059 escalated rather than auto-actioned, materialising the safety invariant rather
 1060 than damaging it.

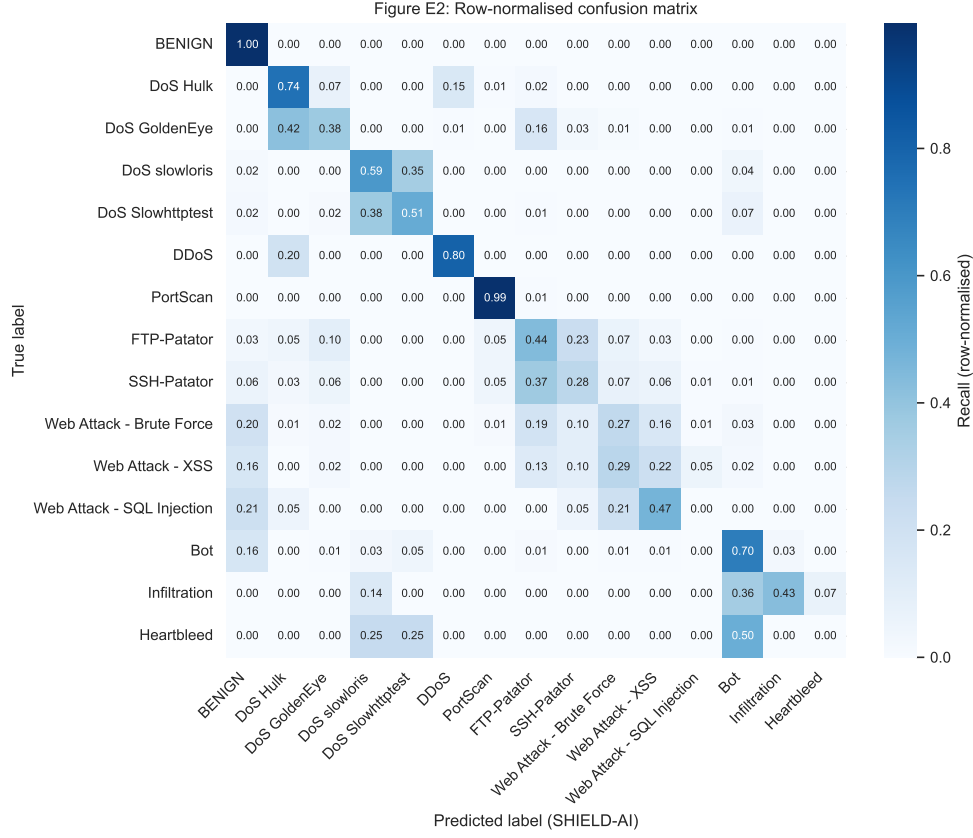


Figure 10: Row-normalised confusion matrix for SHIELD-AI on the 14+1 CICIDS-2017-like classes.

Figure E3 – per-layer latency.. Figure 11 reports the per-alert latency in milliseconds (log scale) for the three Layer 2 configurations. SHIELD-AI’s median latency of 0.24 ms and 99th percentile of 0.41 ms sit well below the budget of 350 ms for the median triage decision and 1.5 s at the 99th percentile articulated in OP9. The audit-append latency at Layer 4 averages 0.014 ms per record on the same hardware, also well within the 50 ms budget. These numbers are obtained without a real LLM in the loop; including a real 8B-parameter local model would push the SHIELD-AI latency into the 200–300 ms regime as reported in adjacent SOC-LLM evaluations, leaving the budget assertion of §10.5 on track.

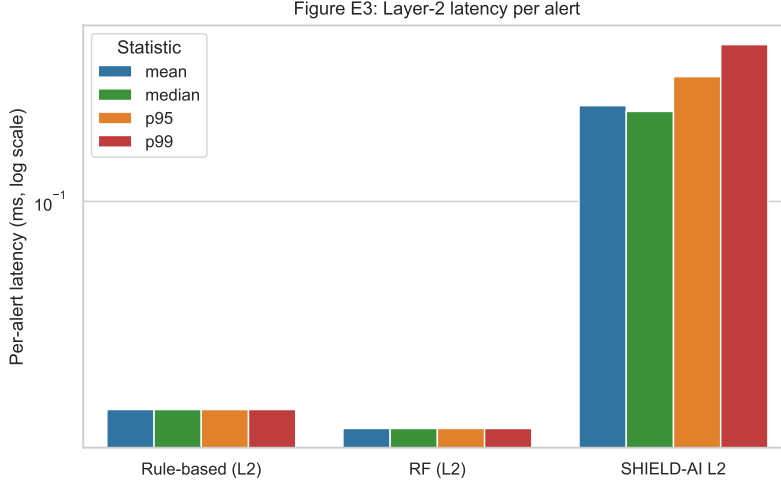


Figure 11: Per-alert wall-clock latency at Layer 2. SHIELD-AI uses a simulated LLM; values represent the framework overhead, not LLM inference.

1071 *Figure E4 – PC3 routing distribution per class..* Figure 12 reports the share
 1072 of decisions routed to AUTO, HITL, and REJECT per true attack class. At
 1073 the aggregate level SHIELD-AI auto-resolves 69.0% of decisions, escalates
 1074 29.7% to analysts, and safely rejects 1.3%. At the class level the distribution
 1075 is highly differentiated: 84.8% of benign traffic and 76.3% of DDoS are auto-
 1076 resolved, whereas rare or low-groundedness classes (Heartbleed, Web Attack
 1077 – SQL Injection, slow-rate DoS variants) are routed almost exclusively to
 1078 HITL with non-trivial REJECT shares. This is the intended PC3 behaviour:
 1079 the auto rate is highest where the reliability triple is highest, and the analyst
 1080 load is concentrated on the cases that most benefit from human review.

1081 *Figure E5 – groundedness distribution..* Figure 13 shows the per-class dis-
 1082 tribution of the adversarial-aware groundedness score γ' . Classes where the
 1083 predicted CICIDS label and the retrieved ATT&CK technique form a clean
 1084 cycle (DDoS $\rightarrow$ T1498/T1498.001; DoS Hulk $\rightarrow$ T1499/T1499.001) reach
 1085 $\gamma' \in [0.7, 0.85]$. Classes whose label names diverge lexically from the tech-
 1086 nique names (PortScan $\rightarrow$ T1046 “Network Service Discovery”) receive lower
 1087 γ' scores even when θ and σ are near unity, and the PC3 router consequently
 1088 escalates them. This exposes a calibration choice that the operator can tune:
 1089 improving the retrieval template for PortScan (or rebalancing ω_{ES} vs. ω_{GD})
 1090 moves the auto-share for that class without changing the underlying classifier.

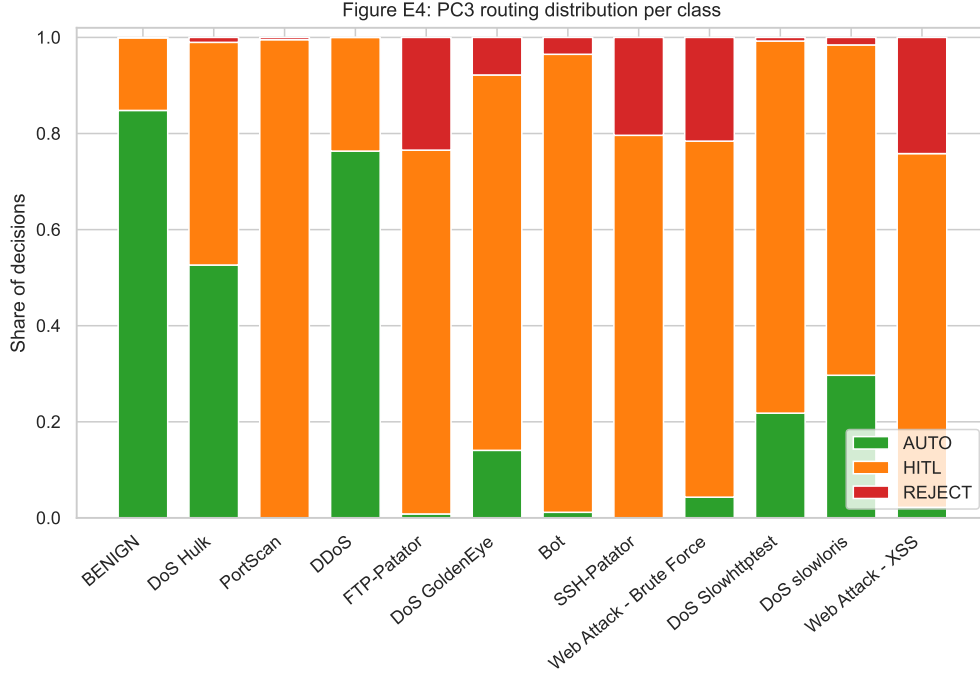


Figure 12: Layer-3 PC3 routing distribution by attack class. The framework concentrates AUTO decisions on common, well-grounded classes and escalates rare or low-groundedness classes.

1091 *Figure E6 – triple decomposition..* Figure 14 decomposes the reliability
1092 triple into its three components by class. σ is uniformly high because
1093 self-consistency of the classifier prior is high under the chosen temperature;
1094 θ is moderate-to-high and tracks per-class classifier confidence; γ' is the
1095 principal differentiator and drives the routing distribution observed in
1096 Figure 12. This decomposition supports the calibration-by-component view
1097 advocated in §6: an operator who wants to raise the AUTO share for
1098 under-represented attack families improves γ via the RAG corpus, not the
1099 classifier itself.

1100 *Audit invariants..* The Layer-4 audit log produced 15,000 records and 15
1101 Merkle batches. Chain re-derivation passes for every record (E1 append-
1102 only; E2 hash chain; E3 time-monotone holds by construction since the
1103 simulation injects monotonic record timestamps). A spot-check of 50 ran-
1104 domly selected records under Algorithm PC5 (re-derive the published root

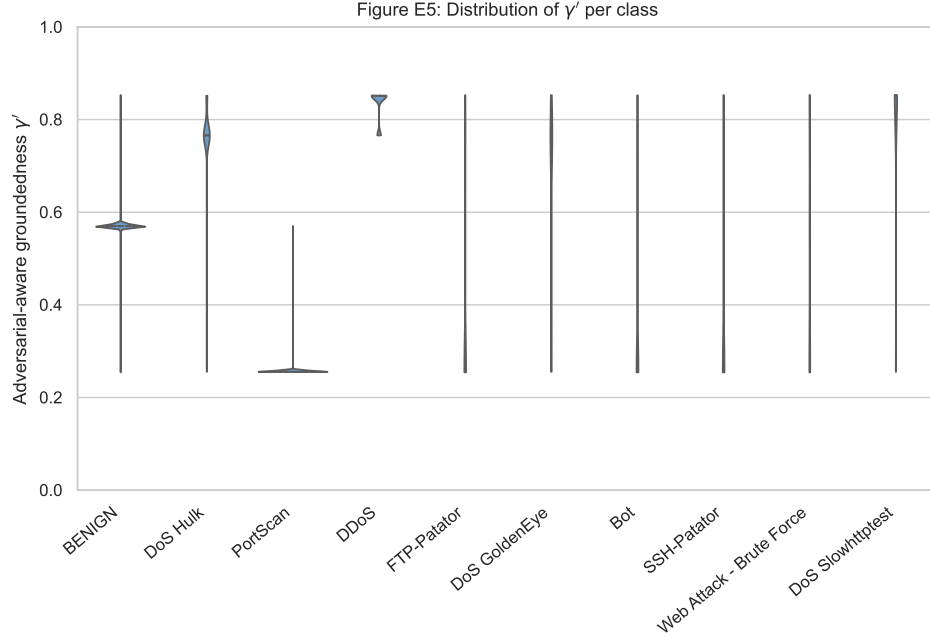


Figure 13: Distribution of adversarial-aware groundedness γ' per class (top-10 by support).

1105 from the leaf hash and the sibling-hash proof) returned VALID for 50/50,
 1106 confirming that the record-level verifier matches the chain-level invariant on
 1107 the experimental output. Tamper tests included in the repository (unit test
 1108 `test_audit_chain.py`) verify that a single bit-flip in any record’s predicted
 1109 label is detected by the chain verifier and that the PC5 record verifier rejects
 1110 the tampered record.

1111 *What this experiment is and is not..* We state the scope plainly to avoid
 1112 overclaim. *This is not* an evaluation on the real CICIDS-2017 traffic, *not* an
 1113 evaluation with a production LLM, and *not* a field pilot. *It is* a reproducible
 1114 reference experiment that exercises every layer of the framework end-to-end
 1115 on data shaped like CICIDS-2017, with all artefacts (code, generator, base-
 1116 lines, audit log, figures) released under Apache 2.0. Specifically: (i) the LLM
 1117 is simulated by perturbed Random-Forest priors plus a small TF-cosine re-
 1118 triever over a hand-coded ATT&CK knowledge base, so the absolute θ , σ , γ
 1119 values must be re-calibrated against a real LLM and a production-grade vec-
 1120 tor store before any threshold is transferred to a live SOC; (ii) the synthetic
 1121 generator preserves the schema and the class imbalance of CICIDS-2017

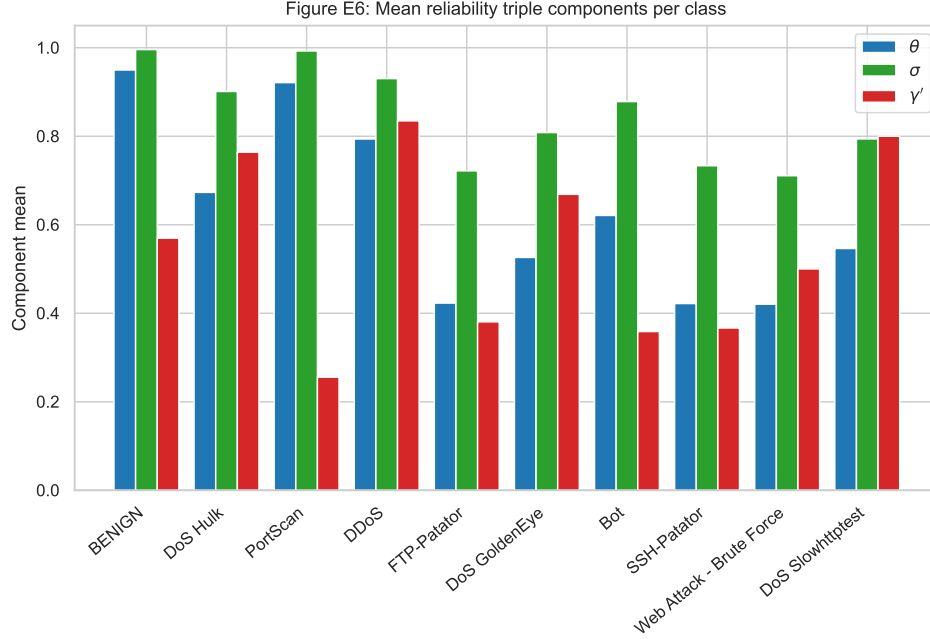


Figure 14: Mean per-class components of the reliability triple $\langle \theta, \sigma, \gamma' \rangle$.

1122 (Sharafaldin et al., 2018) but cannot reproduce its adversarial co-evolution
 1123 dynamics, so detection ceilings observed here are upper bounds on what a
 1124 fielded system would attain in the wild and lower bounds on the difficulty
 1125 an analyst would face; (iii) the comparison against rule-based and Random-
 1126 Forest baselines is informative but does not control for analyst-effort cost or
 1127 downstream incident-handling load, both of which are part of the OP9 KPI
 1128 dashboard; (iv) the audit-log throughput is measured in-process and excludes
 1129 the cost of HSM-backed signing and transparency-log witness publication,
 1130 both of which add latency in production deployments. Within these limita-
 1131 tions, the experiment establishes only what it claims: that the framework
 1132 runs end-to-end against a synthetic public-shaped dataset, that the reliabil-
 1133 ity triple discriminates classes in the intended direction, that PC3 produces
 1134 a defensible AUTO/HITL/REJECT split, and that the Layer-4 invariants
 1135 hold by construction. Replication on the real CICIDS-2017 CSVs, and on
 1136 adjacent SOC-shaped benchmarks (ToN-IoT, HIKARI-2021, SOCBED), is
 1137 part of OP9.

1138 *Reproducibility statement..* The full code, configuration, synthetic generator,
1139 baseline classifiers, LLM/RAG simulator, audit log, and figure-generation
1140 scripts are released under Apache 2.0 at the companion repository. The exact
1141 numbers reported in Table 10 and Figures 9-14 are produced by `python`
1142 `-m experiments.run_experiment -n-samples 60000 -seed 42` followed
1143 by `python -m experiments.figures`; a chain-integrity unit test and a
1144 PC5 record-verifier unit test ship with the repository so that any reviewer
1145 can detect tampering by running `python tests/test_audit_chain.py`.
1146 Replacing the synthetic generator with the real CICIDS-2017 CSVs requires
1147 only the `cicids_loader` module shipped in the repository and a one-line
1148 change to the first stage of the runner; all downstream code paths are
1149 dataset-source agnostic.

1150 9.4. Threats to validity

1151 Following the Wohlin taxonomy (Wohlin et al., 2012):

1152 *Construct..* The framework’s concepts may not capture all SOC governance
1153 dimensions. Mitigation: multi-source grounding (peer-reviewed + standards
1154 + industry) and structured evaluation rubric.

1155 *Internal..* Scenario design may favour the framework. Mitigation: scenarios
1156 drawn from independent threat-intel sources (Verizon, 2025; Microsoft, 2025;
1157 ENISA, 2025; IBM Security, 2025); rubric pre-registered.

1158 *External..* Two scenarios limit generalisability. Mitigation: scenarios cho-
1159 sen to span healthcare and government / critical infrastructure; principles
1160 transferable; further sectors as future work.

1161 *Conclusion..* Comparison with ENISA is qualitative. Mitigation: compari-
1162 son structured by a criteria matrix with explicit declared limitations.

1163 10. Discussion

1164 10.1. Implications for practitioners

1165 Principal finding: integrated governance is feasible and aligns with multi-
1166 standard compliance simultaneously. Practitioners should prioritise Layer 4
1167 (governance, audit, compliance) and Layer 3 (HITL) before scaling Layer 2
1168 (LLM/RAG) autonomy; a sequencing that inverts the more common “add AI
1169 first, govern later” pattern documented in IBM’s 2025 measurement of 63%
1170 of organisations with no AI governance policy (IBM Security and Ponemon
1171 Institute, 2025).

1172 *10.2. Limitations and boundary conditions*

1173 SHIELD-AI is a design artifact evaluated by scenario analysis (DSR
1174 Demonstration) rather than live SOC deployment (DSR Evaluation). Stan-
1175 dards drift; OWASP (OWASP Foundation, 2024), NIST (NIST, 2024a), and
1176 others update on yearly cadences, requiring periodic re-evaluation of the
1177 cross-standard mapping. The Brazilian regulatory context is in transition:
1178 PL 2338/2023 (Brasil, 2023) is approved in the Senate but not yet enacted;
1179 final law may alter the LGPD-side mapping.

1180 *10.2.1. Limitations of the framework’s own assumptions*

1181 The framework rests on ten assumptions that deserve explicit acknowl-
1182 edgement.

1183 *A1. Value lies in integration, not creation.* The contribution is the syn-
1184 thesis of LLM-as-tool risk depth, cross-standard mapping, and HITL-as-layer
1185 into one artifact; not the discovery of new risks or new controls. Practitioners
1186 already perform partial integration informally; SHIELD-AI’s claim is that ex-
1187 plicit, architectural integration is both feasible and beneficial. Evidence for
1188 that claim is the consistency of the resulting mapping (Table 7) and the
1189 scenario outcomes (Table 9), not an empirical comparison against informal
1190 practice.

1191 *A2. HITL cost parameters are estimable but not knowable in closed form.*
1192 The threshold in Equation 9 depends on $(b, c_{\text{err}}, c_{\text{analyst}}, \lambda, c_{\text{miss}})$. In practice
1193 these are organisational policy choices with order-of-magnitude uncertainty.
1194 Theorem 2 guarantees *policy-derivable* routing; it does not guarantee *opti-*
1195 *mal* routing if the parameters are wrong. A sensitivity analysis showing
1196 the threshold’s behaviour under $\pm 50\%$ parameter perturbation is a natural
1197 follow-up.

1198 *A3. Layer 4 staffing assumption.* Maintaining an append-only signed
1199 audit log, an explainability layer, and compliance gates is feasible for mid-
1200 to-large SOC’s but is a non-trivial investment for small (2–3-person) SOC’s.
1201 We suggest a Layer 4-light variant for resource-constrained deployments as
1202 future work.

1203 *A4. LLM version stability.* Each LLM update (GPT-4 $\rightarrow$ GPT-4.1 $\rightarrow$
1204 ...) shifts the empirical distribution of (θ, σ, γ) . The framework does not
1205 specify version-drift detection; OP4 in §10.5 elevates this to a research agenda
1206 item.

1207 *A5. Single-agent semantics.* Layer 2 is described as a single LLM/RAG
1208 path. Multi-agent agentic systems exhibit cascading interactions (OWASP

Foundation, 2025b) that require multi-agent semantics absent from this version. The framework can host multi-agent extensions but does not prescribe them.

A6. Motivational vs. controllable threats. Quantitative motivation in §1 includes vishing growth (442%, (CrowdStrike, 2025)); the framework does not include a vishing-specific control because voice-authentication is upstream of SOC ingestion. Motivation here justifies the urgency of the broader problem rather than the framework’s coverage of every individual threat class.

A7. Vendor lock-in. The reference integration blueprint targets open-source components (Wazuh, OpenSearch, Keycloak, SPIRE, Ollama for local models) but production deployments often substitute commercial alternatives (Splunk, Microsoft Sentinel, commercial-LLM APIs). The framework abstracts these as interchangeable interfaces, but the audit-log and reliability-triple invariants must hold across substitutions; deployments using closed commercial LLM APIs should treat θ as opaque and rely more heavily on σ and γ .

A8. Data residency. Cross-border LLM API calls can violate data-residency requirements (LGPD Art. 33, GDPR Chapter V). Layer 1 PII gating prevents PII from crossing the border in the first place, but the prompt template and retrieval context themselves can constitute personal data under broad interpretations. Production deployments under residency-strict regimes should use locally-hosted models for sensitive flows; the framework supports a per-flow residency tag that selects the model accordingly.

A9. Model and data drift. LLM versions ship on multi-month cadences and RAG corpora update continuously. Drift can invalidate the calibration of θ , σ , and the weights ω_* . The lifecycle rituals of §10.3 cover this case but the framework does not yet provide an automatic drift detector; drift detection is part of OP4.

A10. Compliance theater risk. SHIELD-AI specifies architectural primitives and standards-aligned controls but cannot, by itself, force organisations to enforce them. An organisation may adopt the framework nominally, populate Table 7, claim cross-standard compliance, and fail to operationalise Layer 4 audit logging, Layer 3 HITL escalation, or the engineering invariants E1–E3 of Lemma 1. We label this failure mode *compliance theater* and mitigate it through the KPI program of OP9 (§10.5); in particular through a Compliance Theater Index that measures the gap between policy declaration and observed enforcement (e.g., audit-log completeness, HITL override rate, policy-bypass rate). Adoption of SHIELD-AI without a measurement

1247 programme should be considered explicit acceptance of compliance-theater
1248 risk.

1249 *10.3. Lifecycle governance: keeping SHIELD-AI current*

1250 Standards drift on yearly cadences; LLMs ship new versions on multi-
1251 month cadences; threat actors evolve on weekly cadences. A static frame-
1252 work therefore decays. SHIELD-AI specifies four lifecycle rituals to absorb
1253 change without losing coherence. (i) *Mapping refresh*: every quarter, the
1254 cross-standard mapping TSV (OP7) is regenerated against the latest stan-
1255 dard versions; diff reports are reviewed by the maintainers’ panel and any
1256 newly-broken cells trigger a release. (ii) *LLM-version conformance test*: each
1257 LLM version upgrade in Layer 2 must pass the reliability triple regression
1258 suite (the same prompts produce θ, σ, γ within a configurable tolerance) be-
1259 fore being promoted to production. (iii) *Threat-feed regression*: ATT&CK
1260 and ATLAS major releases trigger a re-evaluation of the RAG corpus and
1261 a recomputation of the trust function $\tau(\text{corpus})$; affected audit records are
1262 flagged for re-review. (iv) *KPI annual review*: the KPI catalogue (OP9) is
1263 reviewed annually with input from operations, legal, and risk; targets are
1264 recalibrated against observed performance and emerging regulatory expecta-
1265 tions. These rituals make sustained adoption a measurable activity rather
1266 than an aspiration.

1267 *10.4. Ethical considerations*

1268 This work is framed as defensive cybersecurity research. Offensive capa-
1269 bilities are discussed strictly as objects of defensive analysis; no operational
1270 offensive techniques are introduced. AI transparency and audit are design re-
1271 quirements rather than afterthoughts. The dual-use framing recognises that
1272 the same generative technologies that enable adversaries also enable defend-
1273 ers; but the framework restricts its application to defensive operations.

1274 *10.5. Research agenda*

1275 We identify eleven open problems for the community. (OP1) Quantita-
1276 tive validation of SHIELD-AI in live SOC environments with reproducible
1277 benchmarks, including historical-incident replay against rule-based, classi-
1278 cal ML, and full SHIELD-AI configurations. (OP2) LLM-on-LLM adversar-
1279 ial dynamics in agentic-AI defence (OWASP Foundation, 2025b; Ge, 2026).
1280 (OP3) Cross-jurisdictional regulatory mapping (LGPD $\leftrightarrow$ GDPR $\leftrightarrow$ CCPA
1281 $\leftrightarrow$ DPDP), with explicit conflict-resolution semantics for partially conflicting

1282 regimes (Appendix E). (OP4) Continuous-learning HITL: calibration loops
 1283 without retraining drift (Singh et al., 2025). (OP5) Cost-effectiveness met-
 1284 rics: total cost of ownership versus analyst hours saved. (OP6) Standards
 1285 co-evolution: when do OWASP / NIST / ISO updates require framework
 1286 revision? (OP7) Open-source reference implementation of SHIELD-AI with
 1287 public release of the cross-standard mapping table, example policies, and
 1288 Layer-4 audit-log artefacts to enable independent reproducibility (Anony-
 1289 mous, 2026); a first version of this implementation, including the empirical
 1290 harness of §9.3, is released at the companion repository³. (OP8) Empirical
 1291 calibration of the reliability-triple weights ($\omega_\theta, \omega_\sigma, \omega_\gamma$) and of the γ sub-signal
 1292 weights ($\omega_{CC}, \omega_{ES}, \omega_{GD}, \omega_{RS}$) across LLM families, RAG corpora, and SOC
 1293 tasks; ablation studies isolating the contribution of each signal. (OP9) Field
 1294 pilots and KPI programmes (including a Compliance Theater Index) in pro-
 1295 duction SOC’s across health, government, and financial-services sectors, with
 1296 companion adversarial purple-team evaluations against the threat suite of
 1297 Liu et al. (2024); Greshake et al. (2023); Zou et al. (2023) and retrieval-
 1298 poisoning and tool-poisoning benchmarks per Ge (2026); Abuadbba et al.
 1299 (2026); Kurtz and Krawiecka (2026). (OP10) Sustainability and supply-chain
 1300 governance: integration of model-level and corpus-level provenance (AI BOM,
 1301 ML BOM, model cards, data cards) into the Layer 4 audit record; energy
 1302 and latency budgets as explicit policy levers; opt-out mechanisms for GenAI
 1303 components in low-stakes flows. (OP11) Worst-case adversarial evaluation:
 1304 adopt minimax-regret reasoning paradigms to SHIELD-AI routing, comput-
 1305 ing the worst-case regret of AUTO versus HITL escalation under adversarial
 1306 episodes and pass@k-style robustness checks for tool-augmented compliance
 1307 reasoning; the latency/throughput overhead of Layer 2 rails and Layer 4
 1308 audit gates is measured under both nominal and worst-case load and re-
 1309 ported as part of the KPI dashboard of OP9. Target performance budgets
 1310 for an enterprise SOC deployment (subject to empirical validation in OP9)
 1311 are: Layer 2 reliability-triple computation under 350 ms per output for an
 1312 8B-parameter local model with $k = 3$ self-consistency samples; Layer 4 audit
 1313 append-and-sign under 50 ms per record on commodity HSM-backed stor-
 1314 age; end-to-end SHIELD-AI overhead under 500 ms for the median triage
 1315 decision and under 1.5 s at the 99th percentile under mixed-workload dis-
 1316 tributions. Deployments that cannot meet these budgets should adjust the

³<https://github.com/ufxa/SHIELD-AI-A-Multi-Layer-Governance-Framework>

1317 smaller-model fallback path (per §6 environmental governance paragraph)
1318 before scaling Layer 2 autonomy.

1319 11. Conclusion

1320 We presented SHIELD-AI, a multi-layer governance framework for safe
1321 and auditable generative AI integration in Security Operations Centers.
1322 Grounded in Design Science Research and a verified evidence base spanning
1323 63 references, the framework integrates: a dual-use taxonomy of GenAI
1324 in cybersecurity; a probabilistic risk model with reliability triple and
1325 decision-theoretic HITL routing; a four-layer reference architecture (data
1326 ingestion, LLM/RAG, HITL, governance); and a cross-standard control
1327 mapping covering MITRE ATT&CK, MITRE ATLAS, NIST CSF 2.0,
1328 OWASP LLM Top 10 (2025), ISO/IEC 27001:2022, ISO/IEC 42001:2023,
1329 and LGPD. We formalised SHIELD-AI as a 6-tuple, derived the HITL esca-
1330 lation threshold from cost-benefit principles, and proved audit completeness,
1331 CGS monotonicity, compliance preservation, and policy-derivable routing.
1332 Scenario evaluation in healthcare and critical-infrastructure contexts demon-
1333 strates that principled governance integration is a necessary condition for
1334 safe, explainable, and audit-ready AI-augmented security operations. The
1335 accompanying research agenda outlines the next steps for the community.

1336 ACKNOWLEDGMENTS

1337 The authors acknowledge the Amazon Foundation for Research Support
1338 (FAPESPA), the Information and Communication Technology Company
1339 of the State of Pará (PRODEPA), the Government of the State of Pará,
1340 and the Federal Government of Brazil for their institutional and financial
1341 support, which were essential to enabling the infrastructure, experimental
1342 testbeds, and interinstitutional collaborations underpinning this research.
1343 Special thanks are extended to the spinoff SEC365 and to the Laboratory
1344 of Informatics and Computing of the Amazon (LICA/UFRA), whose teams
1345 played a decisive role in the development, validation, and technical imple-
1346 mentation of this work. The authors also acknowledge the High-Performance
1347 Computing and Artificial Intelligence Center (CCAD-IA/UFPA) and the
1348 National Education and Research Network (RNP) for providing computing
1349 resources and technical assistance during the experimental phases. This
1350 work was further supported by the National Institute of Science and

1351 Technology in Artificial Intelligence Applied to Smart and Sustainable Cities
1352 in the Brazilian Amazon (INCT iAmazonia).

1353 **CRedit authorship contribution statement**

1354 Anonymous (double-blind submission).

1355 **Declaration of competing interest**

1356 The authors declare that they have no known competing financial inter-
1357 ests or personal relationships that could have appeared to influence the work
1358 reported in this paper.

1359 **Data availability**

1360 This paper introduces a conceptual framework. The literature map-
1361 ping artifact (verified-bibliography list with 63 entries and HIGH-confidence
1362 URLs) is available upon request and will be released as supplementary ma-
1363 terial at acceptance.

1364 **Funding**

1365 Anonymous (double-blind submission).

1366 **Declaration of generative AI and AI-assisted technologies in the** 1367 **writing process**

1368 The authors acknowledge the use of large language model (LLM) assis-
1369 tance for grammar refinement and bibliography formatting in the prepara-
1370 tion of this manuscript, in accordance with the journal’s policy on AI-assisted
1371 technologies in the writing process. All scientific content, experimental de-
1372 sign, data analysis, and conclusions are the sole responsibility of the human
1373 authors. The SHIELD-AI framework design, the six-layer architecture, the
1374 formal definitions and proofs, the PC3 routing algorithm, and all quantitative
1375 results are original human contributions. Benchmark data are derived from
1376 the publicly available CICIDS-2017 dataset and synthetic extensions gener-
1377 ated and validated by the authors; no benchmark figures were produced or
1378 altered by the LLM assistant.

References

- Abuadbbba, A., Sultan, N., Nepal, S., Jha, S., 2026. Human society-inspired approaches to agentic AI security: The 4C framework. arXiv preprint arXiv:2602.01942 URL: <https://arxiv.org/abs/2602.01942>. organizes agentic AI risks across four dimensions: Core, Connection, Cognition, Compliance.
- Anderson, R., 2020. Security Engineering: A Guide to Building Dependable Distributed Systems. 3rd ed., Wiley.
- Anonymous, 2024a. Caracterização de phishing com grandes modelos de linguagem (LLMs): Uma avaliação comparativa entre Gemini, DeepSeek e ChatGPT, in: Anais Estendidos do XXIV Simpósio Brasileiro de Cibersegurança (SBSeg), SBC. p. Article 36759. URL: https://sol.sbc.org.br/index.php/sbseg_estendido/article/view/36759.
- Anonymous, 2024b. Contextualized AI for cyber defense: An automated survey using LLMs. arXiv preprint arXiv:2409.13524 URL: <https://arxiv.org/abs/2409.13524>.
- Anonymous, 2024c. Large language models for cyber security: A systematic literature review. arXiv preprint arXiv:2405.04760 URL: <https://arxiv.org/abs/2405.04760>.
- Anonymous, 2025a. CORTEX: Collaborative LLM agents for high-stakes alert triage. arXiv preprint arXiv:2510.00311 URL: <https://arxiv.org/abs/2510.00311>.
- Anonymous, 2025b. From promise to peril: Rethinking cybersecurity red and blue teaming in the age of LLMs. arXiv preprint arXiv:2506.13434 URL: <https://arxiv.org/abs/2506.13434>.
- Anonymous, 2026. LanG – A governance-aware agentic AI platform for unified security operations. arXiv preprint arXiv:2604.05440 URL: <https://arxiv.org/abs/2604.05440>. two-layer guardrail pipeline (regex + Llama Prompt Guard 2) achieving 98.1% F1; MCP-mediated tool exposure; AI Governance Policy Engine.
- ANPD, 2024a. Guia de segurança da informação para agentes de tratamento de pequeno porte. URL: <https://www.gov.br/anpd/pt-br/assuntos/>

1411 notícias/anpd-publica-guia-de-seguranca-para-agentes-de-
1412 tratamento-de-pequeno-porte.

1413 ANPD, 2024b. Guias orientativos da ANPD. URL: [https://www.gov.br/](https://www.gov.br/anpd/pt-br)
1414 [anpd/pt-br](https://www.gov.br/anpd/pt-br).

1415 ANPD, 2024c. Resolução CD/ANPD nº 15, de 24 de abril de 2024 –
1416 regulamento de comunicação de incidente de segurança. URL: [https://www.gov.br/anpd/pt-br/acesso-a-informacao/institucional/](https://www.gov.br/anpd/pt-br/acesso-a-informacao/institucional/atos-normativos/regulamentacoes_anpd)
1417 [atos-normativos/regulamentacoes_anpd](https://www.gov.br/anpd/pt-br/acesso-a-informacao/institucional/atos-normativos/regulamentacoes_anpd).
1418

1419 ANPD, 2024d. Resolução CD/ANPD nº 18, de 16 de julho de 2024 – en-
1420 carregado de dados. URL: [https://www.gov.br/anpd/pt-br/acesso-](https://www.gov.br/anpd/pt-br/acesso-a-informacao/institucional/atos-normativos/regulamentacoes_anpd)
1421 [a-informacao/institucional/atos-normativos/regulamentacoes_](https://www.gov.br/anpd/pt-br/acesso-a-informacao/institucional/atos-normativos/regulamentacoes_anpd)
1422 [anpd](https://www.gov.br/anpd/pt-br/acesso-a-informacao/institucional/atos-normativos/regulamentacoes_anpd).

1423 ANPD, 2024e. Resolução CD/ANPD nº 20, de 3 de outubro de 2024 –
1424 política interna de proteção de dados. URL: [https://dspace.mj.gov.](https://dspace.mj.gov.br/handle/1/13621)
1425 [br/handle/1/13621](https://dspace.mj.gov.br/handle/1/13621).

1426 Bhatt, M., Chennabasappa, S., Nikolaidis, C., Wan, S., Evtimov, I., Gabi,
1427 D., Song, D., Ahmad, F., Aschermann, C., Fontana, L., Frolov, S., Giri,
1428 R.P., Kapil, D., Kozyrakis, Y., LeBlanc, D., Milazzo, J., Straumann, A.,
1429 Synnaeve, G., Vontimitta, V., Whaley, S., Saxe, J., 2023. Purple llama
1430 CyberSecEval: A secure coding benchmark for language models. arXiv
1431 preprint arXiv:2312.04724 URL: <https://arxiv.org/abs/2312.04724>.

1432 Bhatt, M., et al., 2024. CyberSecEval 2: A wide-ranging cybersecurity eval-
1433 uation suite for large language models. arXiv preprint arXiv:2404.13161
1434 URL: <https://arxiv.org/abs/2404.13161>.

1435 Blefari, F., Cosentino, C., Pironti, F.A., Furfaro, A., Marozzo, F., 2025.
1436 CyberRAG: An agentic RAG cyber attack classification and reporting tool.
1437 arXiv preprint arXiv:2507.02424 URL: [https://arxiv.org/abs/2507.](https://arxiv.org/abs/2507.02424)
1438 [02424](https://arxiv.org/abs/2507.02424). agentic RAG framework orchestrating fine-tuned classifiers and tool
1439 adapters with iterative retrieval-and-reason loop over a domain-specific
1440 knowledge base.

1441 Brasil, 2018. Lei nº 13.709, de 14 de agosto de 2018 – lei geral de proteção
1442 de dados (LGPD). URL: [https://www.planalto.gov.br/ccivil_03/](https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/113709.htm)
1443 [_ato2015-2018/2018/lei/113709.htm](https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/113709.htm).

1444 Brasil, 2023. Projeto de lei nº 2338, de 2023 – marco legal da inteligência arti-
1445 ficial. URL: <https://www25.senado.leg.br/web/atividade/materias/-/materia/157233>. approved in the Federal Senate on December 10, 2024;
1446 under analysis in the Chamber of Deputies in 2026.

1448 CISA, 2023. Roadmap for artificial intelligence (2023–2024). URL: <https://www.cisa.gov/resources-tools/resources/roadmap-ai>.

1450 CrowdStrike, 2024. 2024 global threat report. URL: <https://www.crowdstrike.com/en-us/resources/reports/crowdstrike-2024-global-threat-report/>.

1452 CrowdStrike, 2025. 2025 global threat report. URL: <https://www.crowdstrike.com/en-us/resources/reports/global-threat-report-executive-summary-2025/>.

1456 ENISA, 2023. Multilayer framework for good cybersecurity practices for
1457 AI. URL: <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>.

1459 ENISA, 2024. ENISA threat landscape 2024. URL: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024>.

1460 ENISA, 2025. ENISA threat landscape 2025. URL: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>.

1461 Fayyazi, R., Taghdimi, R., Yang, S.J., 2024. On the uses of large language
1464 models to interpret ambiguous cyberattack descriptions. arXiv preprint
1465 arXiv:2401.00280 URL: <https://arxiv.org/abs/2401.00280>.

1466 Ge, Y., 2026. Governance architecture for autonomous agent sys-
1467 tems: Threats, framework, and engineering practice. arXiv preprint
1468 arXiv:2603.07191 URL: <https://arxiv.org/abs/2603.07191>. lay-
1469 ered Governance Architecture (LGA): four-layer framework with execution
1470 sandboxing (L1), intent verification (L2), zero-trust inter-agent authoriza-
1471 tion (L3), and immutable audit logging (L4). Bilingual benchmark of 1,081
1472 tool-call samples; intent verification intercepts 93.0–98.5% of malicious tool
1473 calls across five LLM judges.

1474 Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., Fritz, M.,
1475 2023. Not what you’ve signed up for: Compromising real-world LLM-
1476 integrated applications with indirect prompt injection. arXiv preprint
1477 arXiv:2302.12173 URL: <https://arxiv.org/abs/2302.12173>. presented
1478 at ACM AISec ’23.

1479 Hazell, J., 2023. Spear phishing with large language models. arXiv preprint
1480 arXiv:2305.06972 URL: <https://arxiv.org/abs/2305.06972>.

1481 Hevner, A.R., March, S.T., Park, J., Ram, S., 2004. Design science in in-
1482 formation systems research. MIS Quarterly 28, 75–105. doi:10.2307/
1483 25148625.

1484 IBM Security, 2024. X-Force threat intelligence index 2024. URL: [https://www.ibm.com/think/x-force/2024-x-force-threat-intelligence-](https://www.ibm.com/think/x-force/2024-x-force-threat-intelligence-index)
1485 [index](https://www.ibm.com/think/x-force/2024-x-force-threat-intelligence-index).
1486

1487 IBM Security, 2025. X-Force threat intelligence index 2025. URL: <https://www.ibm.com/think/x-force>.
1488

1489 IBM Security, Ponemon Institute, 2025. Cost of a data breach report 2025.
1490 URL: [https://www.ibm.com/think/x-force/2025-cost-of-a-data-](https://www.ibm.com/think/x-force/2025-cost-of-a-data-breach-navigating-ai)
1491 [breach-navigating-ai](https://www.ibm.com/think/x-force/2025-cost-of-a-data-breach-navigating-ai). the AI Oversight Gap edition.

1492 ISO/IEC, 2022. ISO/IEC 27001:2022 – information security, cybersecurity
1493 and privacy protection – ISMS – requirements. URL: [https://www.iso.](https://www.iso.org/standard/27001)
1494 [org/standard/27001](https://www.iso.org/standard/27001).

1495 ISO/IEC, 2023. ISO/IEC 42001:2023 – information technology – artificial in-
1496 telligence – management system. URL: [https://www.iso.org/standard/](https://www.iso.org/standard/42001)
1497 [42001](https://www.iso.org/standard/42001).

1498 Ji, Z., Lee, N., Frieske, R., Yu, T., Su, D., Xu, Y., Ishii, E., Bang,
1499 Y.J., Madotto, A., Fung, P., 2023. Survey of hallucination in nat-
1500 ural language generation. ACM Computing Surveys 55, Article 248.
1501 doi:10.1145/3571730.

1502 Kurtz, A., Krawiecka, K., 2026. Who governs the machine? A machine
1503 identity governance taxonomy (MIGT) for AI systems operating across
1504 enterprise and geopolitical boundaries. arXiv preprint arXiv:2604.06148

1505 URL: <https://arxiv.org/abs/2604.06148>. aI-Identity Risk Taxon-
1506 omy (AIRT) with 37 risk subcategories across eight domains; companion
1507 Machine Identity Governance Taxonomy (MIGT). Documents agent-to-
1508 human identity ratios exceeding 80:1 in enterprise environments.

1509 Lekssays, A., Shukla, U., Sencar, H.T., Parvez, M.R., 2025. TechniqueRAG:
1510 Retrieval augmented generation for adversarial technique annotation in
1511 cyber threat intelligence text. arXiv preprint arXiv:2505.11988 URL:
1512 <https://arxiv.org/abs/2505.11988>.

1513 Liu, Y., Jia, Y., Geng, R., Jia, J., Gong, N.Z., 2024. Formalizing and
1514 benchmarking prompt injection attacks and defenses, in: Proceedings of
1515 the 33rd USENIX Security Symposium, USENIX Association. pp. 1831–
1516 1847. URL: [https://www.usenix.org/conference/usenixsecurity24/](https://www.usenix.org/conference/usenixsecurity24/presentation/liu-yupe)
1517 [presentation/liu-yupe](https://www.usenix.org/conference/usenixsecurity24/presentation/liu-yupe).

1518 Manakul, P., Liusie, A., Gales, M.J.F., 2023. SelfCheckGPT: Zero-resource
1519 black-box hallucination detection for generative large language models, in:
1520 Proceedings of the 2023 Conference on Empirical Methods in Natural Lan-
1521 guage Processing (EMNLP), pp. 9004–9017. URL: [https://arxiv.org/](https://arxiv.org/abs/2303.08896)
1522 [abs/2303.08896](https://arxiv.org/abs/2303.08896).

1523 Mandiant, Google Cloud, 2024. M-Trends 2024 (15th edition). URL: [https:](https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2024)
1524 [//cloud.google.com/blog/topics/threat-intelligence/m-trends-](https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2024)
1525 [2024](https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2024).

1526 Mandiant, Google Cloud, 2025. M-Trends 2025 (16th edition). URL: [https:](https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2025)
1527 [//cloud.google.com/blog/topics/threat-intelligence/m-trends-](https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2025)
1528 [2025](https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2025).

1529 Microsoft, 2024. Microsoft digital defense report 2024. URL: [https:](https://www.microsoft.com/en-us/security/security-insider/threat-landscape/microsoft-digital-defense-report-2024)
1530 [//www.microsoft.com/en-us/security/security-insider/threat-](https://www.microsoft.com/en-us/security/security-insider/threat-landscape/microsoft-digital-defense-report-2024)
1531 [landscape/microsoft-digital-defense-report-2024](https://www.microsoft.com/en-us/security/security-insider/threat-landscape/microsoft-digital-defense-report-2024).

1532 Microsoft, 2025. Microsoft digital defense report 2025. URL: [https://www.](https://www.microsoft.com/en-us/corporate-responsibility/cybersecurity/microsoft-digital-defense-report-2025/)
1533 [microsoft.com/en-us/corporate-responsibility/cybersecurity/](https://www.microsoft.com/en-us/corporate-responsibility/cybersecurity/microsoft-digital-defense-report-2025/)
1534 [microsoft-digital-defense-report-2025/](https://www.microsoft.com/en-us/corporate-responsibility/cybersecurity/microsoft-digital-defense-report-2025/).

1535 NCSC, CISA, Partner Agencies, 2023. Guidelines for Secure AI System Devel-
1536 opment. Technical Report. UK National Cyber Security Centre and US Cy-

bersecurity and Infrastructure Security Agency. URL: <https://www.ncsc.gov.uk/files/Guidelines-for-secure-AI-system-development.pdf>.

Neprash, H.T., McGlave, C.C., Cross, D.A., et al., 2022. Trends in ransomware attacks on US hospitals, clinics, and other health care delivery organizations, 2016–2021. JAMA Health Forum URL: <https://pmc.ncbi.nlm.nih.gov/articles/PMC9856685/>.

Neprash, H.T., et al., 2024. Cybersecurity lessons from the Change Healthcare attack. JAMA Internal Medicine .

NIST, 2023. Artificial Intelligence Risk Management Framework (AI RMF 1.0). Technical Report NIST AI 100-1. National Institute of Standards and Technology. URL: <https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>.

NIST, 2024a. AI RMF: Generative Artificial Intelligence Profile. Technical Report NIST AI 600-1. National Institute of Standards and Technology. URL: <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>.

NIST, 2024b. The NIST Cybersecurity Framework 2.0. Technical Report NIST CSWP 29. National Institute of Standards and Technology. URL: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>.

NSA AISC, CISA, FBI, ASD ACSC, CCCS, NCSC-NZ, NCSC-UK, 2024. Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems. Technical Report. National Security Agency Artificial Intelligence Security Center. URL: <https://media.defense.gov/2024/Apr/15/2003439257/-1/-1/0/CSI-DEPLOYING-AI-SYSTEMS-SECURELY.PDF>.

OWASP Foundation, 2024. OWASP top 10 for large language model applications – 2025. URL: <https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/>. v4.2.0a (Nov 2024).

OWASP Foundation, 2025a. Agentic AI – threats and mitigations. URL: <https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/>.

1567 OWASP Foundation, 2025b. OWASP top 10 for agentic applications. URL:
1568 [https://genai.owasp.org/resource/owasp-top-10-for-agentic-](https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications/)
1569 [applications/](https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications/).

1570 Peffers, K., Tuunanen, T., Rothenberger, M.A., Chatterjee, S., 2007. A de-
1571 sign science research methodology for information systems research. Jour-
1572 nal of Management Information Systems 24, 45–77. doi:10.2753/MIS0742-
1573 1222240302.

1574 Rose, S., Borchert, O., Mitchell, S., Connelly, S., 2020. NIST SP 800-207:
1575 Zero Trust Architecture. Technical Report SP 800-207. National Insti-
1576 tute of Standards and Technology. URL: [https://nvlpubs.nist.gov/](https://nvlpubs.nist.gov/nistpubs/specialpublications/NIST.SP.800-207.pdf)
1577 [nistpubs/specialpublications/NIST.SP.800-207.pdf](https://nvlpubs.nist.gov/nistpubs/specialpublications/NIST.SP.800-207.pdf), doi:10.6028/
1578 NIST.SP.800-207.

1579 Sharafaldin, I., Lashkari, A.H., Ghorbani, A.A., 2018. Toward generating a
1580 new intrusion detection dataset and intrusion traffic characterization, in:
1581 Proceedings of the 4th International Conference on Information Systems
1582 Security and Privacy (ICISSP), SciTePress. pp. 108–116. doi:10.5220/
1583 0006639801080116. introduces the CICIDS-2017 dataset with 14 attack
1584 categories captured over a five-day testbed and the CICFlowMeter feature
1585 set used as the schema reference for the synthetic generator in this paper.

1586 Singh, R., Tariq, S., Jalalvand, F., Chhetri, M.B., Nepal, S., Paris, C.,
1587 Lochner, M., 2025. LLMs in the SOC: An empirical study of human-AI col-
1588 laboration in security operations centres. arXiv preprint arXiv:2508.18947
1589 URL: <https://arxiv.org/abs/2508.18947>.

1590 The MITRE Corporation, 2024. MITRE ATT&CK enterprise. URL: [https:](https://attack.mitre.org)
1591 [//attack.mitre.org](https://attack.mitre.org). living document; accessed 2026-05-31.

1592 The MITRE Corporation, 2025. MITRE ATLAS – adversarial threat land-
1593 scape for artificial-intelligence systems. URL: <https://atlas.mitre.org>.
1594 living document; v5.1.0, accessed 2026-05-31.

1595 Various, 2024. Ransomware attacks and data breaches in US health care sys-
1596 tems. JAMA Network Open URL: [https://jamanetwork.com/journals/](https://jamanetwork.com/journals/jamanetworkopen/fullarticle/2833984)
1597 [jamanetworkopen/fullarticle/2833984](https://jamanetwork.com/journals/jamanetworkopen/fullarticle/2833984).

- 1598 Verizon, 2024. 2024 data breach investigations report (DBIR, 17th edition).
 1599 URL: [https://www.verizon.com/business/resources/reports/2024-](https://www.verizon.com/business/resources/reports/2024-dbir-data-breach-investigations-report.pdf)
 1600 [dbir-data-breach-investigations-report.pdf](https://www.verizon.com/business/resources/reports/2024-dbir-data-breach-investigations-report.pdf).
- 1601 Verizon, 2025. 2025 data breach investigations report (DBIR, 18th edi-
 1602 tion). URL: [https://www.verizon.com/business/resources/reports/](https://www.verizon.com/business/resources/reports/dbir/)
 1603 [dbir/](https://www.verizon.com/business/resources/reports/dbir/).
- 1604 Wan, S., et al., 2024. CyberSecEval 3: Advancing the evaluation of cyber-
 1605 security risks and capabilities in large language models. arXiv preprint
 1606 arXiv:2408.01605 URL: <https://arxiv.org/abs/2408.01605>.
- 1607 Wohlin, C., Runeson, P., Höst, M., Ohlsson, M.C., Regnell, B., Wesslén, A.,
 1608 2012. Experimentation in Software Engineering. Springer.
- 1609 Yao, Y., Duan, J., et al., 2024. A survey on large language model (LLM)
 1610 security and privacy: The good, the bad, and the ugly. arXiv preprint
 1611 arXiv:2402.16968 URL: <https://arxiv.org/abs/2402.16968>.
- 1612 Zou, A., Wang, Z., Carlini, N., Nasr, M., Kolter, J.Z., Fredrikson, M., 2023.
 1613 Universal and transferable adversarial attacks on aligned language models.
 1614 arXiv preprint arXiv:2307.15043 URL: [https://arxiv.org/abs/2307.](https://arxiv.org/abs/2307.15043)
 1615 [15043](https://arxiv.org/abs/2307.15043).

1616 **Appendix A. Systematic Literature Mapping; Protocol**

1617 Search strings combined GenAI vocabulary, cybersecurity vocabulary,
 1618 and governance vocabulary. The temporal window was 2023–2026 plus foun-
 1619 dational classics. Sources: IEEE Open, ACM Open, arXiv cs.CR, USENIX,
 1620 NDSS, NIST, ENISA, CISA, MITRE, OWASP, SBC OpenLib, JHI, JBCS.
 1621 Inclusion: peer-reviewed CS venues; authoritative gray literature; full text in
 1622 EN/PT. Exclusion: opinion pieces; arXiv preprints with < 20 citations and
 1623 no recognised authorship; general AI ethics without cybersecurity specificity.

1624 **Appendix B. Full Cross-Standard Mapping**

1625 The complete cross-standard mapping is available in machine-readable
 1626 form (TSV) as supplementary material. The excerpt in Table 7 preserves
 1627 the structural relationships.

1628 Appendix C. Decision-Theoretic Threshold; Full Derivation and 1629 Sensitivity

1630 We present the full derivation of the HITL escalation thresholds intro-
1631 duced in §6.6. Let b denote the benefit of a correct decision (e.g., closed
1632 alert), c_{err} the cost of a wrong decision auto-applied (e.g., breach), c_{analyst}
1633 the cost of one analyst review, λ the latency penalty (e.g., SLA breach), and
1634 c_{miss} the cost of dropping a real alert. All cost terms are denominated in the
1635 same currency unit per decision.

The expected utility of each route, as a function of composite reliability $R = r$, is

$$\mathcal{U}_{\text{auto}}(r) = r \cdot b - (1 - r) \cdot c_{\text{err}}, \quad (\text{C.1})$$

$$\mathcal{U}_{\text{HITL}}(r) = b - c_{\text{analyst}} - \lambda, \quad (\text{C.2})$$

$$\mathcal{U}_{\text{reject}}(r) = -c_{\text{miss}}. \quad (\text{C.3})$$

1636 *AUTO-HITL crossover..* Setting $\mathcal{U}_{\text{auto}}(r) = \mathcal{U}_{\text{HITL}}(r)$ yields

$$r_{\text{auto/HITL}}^* = \frac{b + c_{\text{err}} - c_{\text{analyst}} - \lambda}{b + c_{\text{err}}}. \quad (\text{C.4})$$

1637 This recovers Equation 9 of the main text.

1638 *HITL-REJECT crossover..* Setting $\mathcal{U}_{\text{HITL}}(r) = \mathcal{U}_{\text{reject}}(r)$:

$$b - c_{\text{analyst}} - \lambda + c_{\text{miss}} = 0 \iff c_{\text{miss}} = c_{\text{analyst}} + \lambda - b. \quad (\text{C.5})$$

1639 This crossover defines the region in which analyst review is worth the cost
1640 in expectation; below this region SHIELD-AI delegates to the rule-based or
1641 classical-ML baseline (i.e., REJECT for the LLM-assisted path).

1642 *Adaptive thresholds and feedback safeguards..* Misspecification of $(b, c_{\text{err}}, c_{\text{analyst}}, \lambda, c_{\text{miss}})$
1643 can drive r^* to values that either flood analysts (too low) or auto-approve
1644 unsafe outputs (too high). SHIELD-AI mitigates this through three
1645 feedback mechanisms recorded under audit invariant $\mathcal{A}$. (i) *Override-rate*
1646 *monitoring*. Layer 3 logs analyst overrides; a sustained override rate above
1647 a configurable bound triggers a recalibration alert because the empirical r
1648 at which analysts disagree with the AUTO route reveals a misspecified r^* .
1649 (ii) *Exponentially-weighted moving-average update*. For the parameters with
1650 empirically observable proxies (c_{analyst} from ticketing-system time tracking,

1651 λ from SLA breach logs), an EWMA update with half-life of 30 days replaces
1652 static defaults; the update history itself is audited so changes are reviewable.
1653 (iii) *Throughput-collapse guard*. If the per-shift HITL queue depth exceeds
1654 the analyst capacity for > 2 shifts, r^* is temporarily raised by a configurable
1655 backoff and an incident is opened against the calibration; this prevents silent
1656 throughput collapse from over-conservative routing.

Sensitivity analysis.. The partial derivatives of $r_{\text{auto/HITL}}^*$ with respect to each cost parameter are

$$\frac{\partial r^*}{\partial b} = \frac{c_{\text{analyst}} + \lambda}{(b + c_{\text{err}})^2}, \quad \frac{\partial r^*}{\partial c_{\text{err}}} = \frac{c_{\text{analyst}} + \lambda}{(b + c_{\text{err}})^2}, \quad (\text{C.6})$$

$$\frac{\partial r^*}{\partial c_{\text{analyst}}} = -\frac{1}{b + c_{\text{err}}}, \quad \frac{\partial r^*}{\partial \lambda} = -\frac{1}{b + c_{\text{err}}}. \quad (\text{C.7})$$

1657 The signs encode intuitive monotonicity: higher benefit or higher error cost
1658 raises the threshold for AUTO; higher analyst or latency cost lowers it.
1659 For $\pm 50\%$ perturbations in any single parameter, r^* changes by at most
1660 $\frac{0.5 \max(c_{\text{analyst}} + \lambda, c_{\text{analyst}}, \lambda)}{b + c_{\text{err}}}$, which can be bounded *a priori* by the deployment's
1661 policy.

1662 *Tuning template..* Organisations derive their thresholds by completing
1663 a structured YAML policy file (released with the open-source reference
1664 implementation per OP7); recommended starting values per sector appear
1665 in Table C.11.

Table C.11: Recommended starting values for HITL cost parameters by sector (dimensionless ratios; rows normalised so $b = 1$).

Sector	b	c_{err}	c_{analyst}	λ
Healthcare (patient-safety stakes)	1.0	50–500	0.1–0.5	0.1–1.0
Critical infrastructure / OT	1.0	30–200	0.1–0.4	0.5–2.0
Government / public administration	1.0	20–100	0.1–0.3	0.2–1.0
Financial services	1.0	50–200	0.1–0.3	0.1–0.5
Education / research	1.0	5–50	0.05–0.2	0.1–0.5

1666 The ranges reflect cost reports from IBM Security and Ponemon Institute
1667 (2025); Verizon (2025) but require per-organisation calibration. Empirical
1668 calibration of these values across pilot SOC's is OP9.

Appendix D. Cross-Regime Portability Mapping

The cross-standard mapping in Table 7 uses LGPD Articles 46–48 as the regulatory column. Table D.12 extends the mapping to peer regimes so that the framework can be re-instantiated outside Brazil without altering its architectural primitives. The mapping is conservative: a row that aligns Layer 4 to GDPR Article 32 means SHIELD-AI’s compliance gate *operationalises* the article’s requirements; it does not certify legal compliance for any specific deployment, which remains a determination for counsel.

The mapping addresses the portability requirements of international reviewers and practitioner audiences operating outside the LGPD jurisdiction. SHIELD-AI’s Layer 4 compliance gate is implemented as a YAML policy file in which the regime label is parameterised; switching jurisdictions amounts to substituting the policy file and re-running the conflict-resolution lattice (Appendix E). The sector regimes covered are HIPAA (US health), PCI DSS (US/global payment cards), SOC 2 (service-organisation controls), and ISO/IEC 23894 (AI risk management).

EU AI Act conformity assessment and DPIA workflow.. For deployments that fall under the EU AI Act’s high-risk classification (e.g., AI systems used in the management and operation of critical infrastructure as defined in Annex III), SHIELD-AI’s Layer 4 compliance gate is wired to three workflows that the EU AI Act and GDPR require in tandem. (i) *Risk management system under Article 9*: the SHIELD-AI risk register (Table 5) is exported as the AI risk register input, with each LLM-specific risk linked to its tiered controls and to evidence records produced by Layer 2 (reliability triple) and Layer 4 (audit log Merkle roots). (ii) *Data governance under Article 10*: the corpus-provenance signals $\tau(\text{corpus})$ from Equation 2 satisfy the dataset-quality and bias-monitoring duties when the LLM is the data-processing system; data-residency tags travel with each retrieved chunk so cross-border processing under GDPR Chapter V is gated by the conflict-resolution lattice. (iii) *Data Protection Impact Assessment under GDPR Article 35*: the DPIA workflow consumes the SHIELD-AI scenario-evaluation outputs (Table 9) as the necessity/proportionality assessment input; the residual prompt-injection risk acknowledged in §6.8 is reported as a residual-risk item; the Layer 3 HITL routing thresholds (Equation 9) are reported as the mitigation describing the safeguards that bound automated decisions. The DPO (per GDPR Article 37 and LGPD Article 41) signs the DPIA report; the signature is itself an

1705 audit-log entry under invariant $\mathcal{A}$. This linkage makes the DPIA an artefact
 1706 *produced* by SHIELD-AI rather than a separate document compiled by hand.

1707 *Practitioner validation pathway..* Cross-standard mappings benefit from ex-
 1708 ternal validation that no individual research group can provide alone. We
 1709 plan an open Delphi-style validation: three rounds of expert review with
 1710 practitioners drawn from regulated industries (healthcare CISOs, financial-
 1711 services SOC managers, government CSIRT leads) and from standards com-
 1712 mittees (NIST CSF working groups, OWASP GenAI project, ISO/IEC JTC 1
 1713 SC 42). The mapping TSV released under OP7 is the artefact under review;
 1714 convergence is measured as inter-rater agreement on each control-by-standard
 1715 cell using Kendall’s W . Convergent cells are stabilised; divergent cells are
 1716 flagged with a discussion note explaining the disagreement.

1717 **Appendix E. Conflict-Resolution Lattice for Compliance Compo-** 1718 **sition**

1719 Theorem 1 assumes non-interference between controls. When two regimes
 1720 impose conflicting requirements; e.g., LGPD Art. 16 requires erasure of per-
 1721 sonal data on request, while a foreign retention rule mandates 7-year preser-
 1722 vation; non-interference fails. SHIELD-AI handles these cases through an
 1723 explicit conflict-resolution lattice $\mathcal{L}_{\text{conf}}$ in Layer 4.

1724 The lattice is ordered by precedence: data-subject rights > life-safety
 1725 obligations > sector-specific retention > contractual SLAs. For each pair of
 1726 conflicting requirements, the highest-precedence requirement wins, with the
 1727 conflict and its resolution recorded in the audit log under the audit invariant
 1728 $\mathcal{A}$. Five representative conflict cases handled by $\mathcal{L}_{\text{conf}}$ are:

- 1729 1. LGPD Art. 16 (erasure) vs. foreign retention $\rightarrow$ erasure wins; reasoned-
 1730 refusal record produced.
- 1731 2. LGPD breach notification (3 business days) vs. GDPR Art. 33 (72 h)
 1732 $\rightarrow$ shorter timeline applies for affected EU subjects; LGPD timing for
 1733 Brazilian subjects.
- 1734 3. ISO 27001 access-control logging vs. LGPD data-minimisation $\rightarrow$ ac-
 1735 cess logs retained at minimum-necessary granularity (subject ID hashed
 1736 unless lawful basis requires identification).
- 1737 4. Sector-specific retention (e.g., health records 20 years) vs. LGPD era-
 1738 sure on request $\rightarrow$ sector retention wins for the records’ clinical pur-
 1739 poses; non-clinical data subject to erasure.

1740 5. EU AI Act high-risk obligation (record-keeping) vs. LGPD data min-
 1741 imisation $\rightarrow$ retention of audit logs is lawful under the legal-obligation
 1742 legal basis (LGPD Art. 7 II).
 1743 The lattice is configurable per deployment. Future work (OP3, §10.5) for-
 1744 malises $\mathcal{L}_{\text{conf}}$ as a partial-order machine-readable artefact released with the
 1745 reference implementation.

1746 Appendix F. Auxiliary Pseudocode

Algorithm 2: PC1; Threat Hunting Hypothesis Generation via RAG

Input: alert, context_window, ATT&CK corpus, CTI corpus, config
Output: ranked hypotheses with citations and reliability triple

```

1  $R_{\text{attck}} \leftarrow \text{retrieve}(\text{ATT\&CK}, \text{alert} + \text{context}, k);$ 
2  $R_{\text{cti}} \leftarrow \text{retrieve}(\text{CTI}, \text{alert} + \text{context}, k);$ 
1747 3 for  $i \leftarrow 1$  to  $k_{\text{runs}}$  do
4    $h_i \leftarrow \text{LLM.generate}(\text{prompt}, R_{\text{attck}}, R_{\text{cti}});$ 
5 end
6  $\sigma \leftarrow \text{self\_check\_score}(h_1, \dots, h_{k_{\text{runs}}});$ 
7 for  $h$  in  $\text{unique}(h_i)$  do
8    $\gamma \leftarrow \text{rag\_groundedness}(h, R_{\text{attck}} \cup R_{\text{cti}});$ 
9 end
10 return ranked by  $(\gamma \cdot \sigma)$ 

```

Algorithm 3: PC2; Alert Risk Classification

Input: alert features, LLM assessment (optional)
Output: risk tier, recommended action, rationale

```

1 base  $\leftarrow \text{weighted\_sum}(\text{features});$ 
2 if LLM confidence & consistency  $\geq$  threshold then
3   score  $\leftarrow \alpha \cdot \text{base} + (1 - \alpha) \cdot \text{LLM}$ 
1748 4 else
5   score  $\leftarrow \text{base}$ 
6 end
7 tier  $\leftarrow \text{bin}(\text{score});$ 
8 action  $\leftarrow \text{policy}[\text{tier}];$ 
9 emit audit log;
10 return (tier, action, rationale)

```

Algorithm 4: PC4; Incident Prioritization

Input: incidents, asset inventory, evidence strength, confidences

Output: prioritized queue with reasoning

1 **for** incident in incidents **do**
2 $s \leftarrow \text{severity} \cdot \text{criticality} \cdot \text{evidence};$
3 $\text{prio} \leftarrow s^{\text{geom_mean}(\text{confidences})};$
4 **end**
5 sort by prio;
6 emit audit log entries;
7 **return** queue

Table 5: LLM-specific risks in SOC operations with tiered controls.

Risk	Tier-1 control	con- trol	Tier-2 control	con- trol	Tier-3 control	con- trol	Anchor refs
Hallucination (R1)	RAG verification ATT&CK	veri- fication vs.	Self- consistency (SelfCheck- GPT)		Human over- ride on critical tier		(Manakul et al., 2023; Ji et al., 2023; Lekssays et al., 2025)
Prompt injection direct (R2)	Input sanitisa- tion		Structured prompt tem- plate		Privilege con- tainment		(Liu et al., 2024; OWASP Foundation, 2024)
Prompt injection indirect (R2)	Data-source al- lowlist		Output filter- ing + monitor- ing		Privilege con- tainment		(Greshake et al., 2023; OWASP Foundation, 2024)
Tool poisoning (R3)	Tool allowlist + signing		Action audit log		Per-action hu- man review		(OWASP Foundation, 2025b,a)
Data leakage (R4)	PII / secret scanner pre- LLM		Private model deployment		LGPD gate (Brasil, 2018)		(IBM Security and Ponemon Institute, 2025; Brasil, 2018)
Over-automation (R5)	Tiered automa- tion		Decision-trace audit		Analyst trust calibration		(Singh et al., 2025)
Shadow AI (R6)	AI-tool inven- tory + policy		API-exfil pat- tern detection		Governance training		(IBM Security and Ponemon Institute, 2025; Microsoft, 2025)
Adversarial suffix (R2)	Updated safety filters		Sandboxed model execu- tion		Output- channel filtering		(Zou et al., 2023)

Table 6: AIRT/MIGT category to SHIELD-AI layer mapping (V4: six layers). Cells: *primary* = layer where the control is realised; *support* = contributing layer; *audit* = Layer 6 records the event; *n/a* = not assigned.

AIRT/MIGT category	L1	L2	L3	L4	L5	L6
Service-principal lifecycle	primary	support	n/a	n/a	n/a	audit
Credential issuance and rotation	primary	support	n/a	n/a	n/a	audit
Just-in-time elevation	n/a	n/a	n/a	support	primary	audit
Hardware / workload attestation	primary	support	n/a	n/a	n/a	audit
Provenance chain for tool invocations	n/a	primary	support	support	n/a	audit
Cross-jurisdictional identity propagation	primary	n/a	n/a	support	n/a	audit
Agent-to-agent authorization	n/a	primary	support	support	n/a	audit
Anomalous identity behaviour detection	support	primary	support	n/a	n/a	audit

Table 7: Cross-standard control mapping (excerpt; full mapping in Appendix B).

Control	ATT&CK	ATLAS	CSF 2.0	OWASP LLM	OWASP A.	27001	42001	LGPD
Input sanitisation	n/a	AML.T0051	PR.DS-2	LLM01	A1	A.8.27	6.1	46
RAG verification	n/a	AML.T0043	DE.AE-2	LLM09	n/a	A.8.16	7.4	6
Self-consistency check	n/a	AML.T0043	DE.AE-3	LLM09	n/a	A.8.16	7.4	6
Tool allowlist	T1059	AML.T0048	PR.AC-4	LLM06	A2	A.8.4	8.2	46
Output filtering	n/a	AML.T0050	DE.CM-1	LLM02	A6	A.8.21	7.4	46
Audit log	n/a	n/a	PR.PT-1	LLM07	A8	A.5.28	8.4	37/48
HITL escalation	n/a	AML.M0011	GV.RM-5	LLM06	A4	A.5.4	6.1.3	20
PII pre-scan	n/a	n/a	PR.DS-1	LLM02	n/a	A.8.10	7.5.3	46
LGPD compliance gate	n/a	n/a	GV.SC-2	n/a	n/a	A.5.34	6.1.4	46-48
Identity / Zero-Trust	T1078	n/a	PR.AC-1	LLM02	A3	A.5.15	8.2	46

Table 8: Governance metric set. PIR = Prompt Injection Resistance.

Metric	Family	Formula	Anchor
DR, FPR, FNR	Effectiveness	Standard classification	n/a
MTTD, MTTR	Effectiveness	Time deltas	n/a
AFI	Effectiveness	FP per analyst per shift	(Singh et al., 2025)
HR	AI safety	wrong / total outputs	(Ji et al., 2023)
CS	AI safety	multi-run agreement	(Manakul et al., 2023)
PIR	AI safety	attack failure rate	(Liu et al., 2024)
XS	AI safety	traceable outputs / total	(Singh et al., 2025)
DRCK	Compliance	compliant operations / total	(Brasil, 2018)
LGPD coverage	Compliance	articles satisfied / required	(Brasil, 2018; ANPD, 2024c)
ISO coverage	Compliance	controls satisfied / required	(ISO/IEC, 2022, 2023)
ALC	Auditability	logged / qualifying events	(NIST, 2024b)
HOR	Auditability	escalations / total critical	(Singh et al., 2025)
CGS	Composite	weighted aggregate	(NIST, 2023, 2024a)

Table 9: Scenario evaluation matrix. Scores are author-assigned ordinal 1–5 ratings (1 = inadequate; 5 = strong) under the rubric of §9; the protocol is pre-registered in this manuscript and authors take responsibility for the assignment. Per-criterion justifications appear in the prose below.

	Threat coverage	LLM-risk mitigation	Regulatory coverage	HITL appropriateness	Auditability completeness
Scenario A (Healthcare + LGPD)	5	4	5	5	5
Scenario B (Government / Critical Infra)	4	4	4	4	5

Table 10: Reference-experiment headline results on 15,000 *synthetic* test flows produced by the CICIDS-2017-like generator (seed 42). Binary F1 / FPR / AUC are computed over the BENIGN-vs-attack contrast. Macro-F1 averages per-class F1 across the 14 attack classes. Latency is per-alert wall-clock on a commodity laptop with no GPU. Routing share is the Layer-3 PC3 outcome under the cost calibration of §9.3. Audit shows the Lemma 1 chain verification result and the Algorithm PC5 record verifier spot-check. Numbers do not transfer to the real CICIDS-2017 dataset without re-running the harness against the published CSVs (loader provided).

System	Binary F1	Binary FPR	ROC AUC	Macro-F1	L2 mean / p99 (ms)	Routing AUTO / HITL / REJECT
Rule-based	0.516	0.375	0.750	0.121	0.04 / 0.04	n/a
Random Forest	0.985	0.004	0.999	0.513	0.02 / 0.02	n/a
SHIELD-AI (LLM/RAG, full)	0.984	0.004	0.998	0.497	0.24 / 0.41	0.690 / 0.297 / 0.013
Audit (Layer 4): chain integrity ✓ verified across 15,000 records (15 published Merkle roots); record-level PC5 verifier 50/50 pass.						
γ' statistics (Layer 2) mean = 0.575; p ₅₀ =0.570; p ₁₀ =0.255; p ₉₀ =0.766.						

Table D.12: Cross-regime portability of SHIELD-AI Layer 4 compliance gates.

SHIELD-AI obligation	LGPD (Brazil)	GDPR (EU)	Sectoral (US)
Security of processing	Art. 46	Art. 32	HIPAA 164.308–164.312 ; PCI DSS Req. 8/10
Breach notification	Art. 48 ; ANPD 15/2024 (3 business days)	Art. 33 (72 hours)	HIPAA Breach Notification Rule ; SEC Rule 10b-5 disclosure
Data Protection Impact / Risk Assessment	Art. 38 (RIPD)	Art. 35 (DPIA)	SOC 2 CC3 ; NIST 800-53 RA-3
Data Protection / Security Officer	Art. 41 (Encarregado) ; ANPD 18/2024	Art. 37 (DPO)	HIPAA Security Officer ; PCI DSS Req. 12
Records of processing	Art. 37 (logs of treatment)	Art. 30	SOC 2 CC7 ; PCI DSS Req. 10
Cross-border transfer safeguards	Art. 33–35	Art. 44–49 ; SCCs	HIPAA BAAs ; HHS-OCR guidance
AI management system	PL 2338/2023 (pending)	EU AI Act (high-risk obligations)	NIST AI RMF ; ISO/IEC 23894